CIS Benchmarks

CIS Microsoft 365 Foundations Benchmark

v1.2.0 - 07-06-2020

ARCHIVE

Terms of Use

Please see the below link for our current terms of use:

https://www.cisecurity.org/cis-securesuite/cis-securesuite-membership-terms-of-use/

ARCHIVE

Table of Contents

Terms of Use 1
Overview 7
Intended Audience 7
Consensus Guidance 7
Typographical Conventions 8
Assessment Status 8
Profile Definitions 9
Acknowledgements 10
Recommendations 11
1 Account / Authentication 11
1.1 Azure Active Directory 11
1.1.1 (L1) Ensure multifactor authentication is enabled for all users in administrative roles (Automated) 11
1.1.2 (L2) Ensure multifactor authentication is enabled for all users in all roles (Manual) 14
1.1.3 (L1) Ensure that between two and four global admins are designated (Automated) 17
1.1.4 (L1) Ensure self-service password reset is enabled (Automated) 20
1.1.5 (L1) Ensure that password protection is enabled for Active Directory (Manual) 22
1.1.6 (L1) Enable Conditional Access policies to block legacy authentication (Automated) 24
1.1.7 (L1) Ensure that password hash sync is enabled for resiliency and leaked credential detection (Manual) 26
1.1.8 (L1) Enabled Identity Protection to identify anomalous logon behavior (Manual) 28
1.1.9 (L2) Enable Azure AD Identity Protection sign-in risk policies (Manual) 30
1.1.10 (L2) Enable Azure AD Identity Protection user risk policies (Manual) 32
1.1.11 (L2) Use Just In Time privileged access to Office 365 roles (Manual) 34

ARCHIVE

1.1.12 (L1) Ensure Security Defaults is disabled on Azure Active Directory (Manual) 38
1.2 (L1) Ensure modern authentication for Exchange Online is enabled (Automated) 40
1.3 (L1) Ensure modern authentication for Skype for Business Online is enabled (Automated) 43
1.4 (L1) Ensure modern authentication for SharePoint applications is required (Automated) 45
1.5 (L1) Ensure that Office 365 Passwords Are Not Set to Expire (Automated) 47
2 Application Permissions 49
2.1 (L2) Ensure third party integrated applications are not allowed (Manual) 49
2.2 (L2) Ensure calendar details sharing with external users is disabled (Automated) 51
2.3 (L2) Ensure O365 ATP SafeLinks for Office Applications is Enabled (Automated) 53
2.4 (L2) Ensure Office 365 ATP for SharePoint, OneDrive, and Microsoft Teams is Enabled (Automated) 56
2.5 (L2) Ensure Office 365 SharePoint infected files are disallowed for download (Automated) 58
2.6 (L2) Ensure user consent to apps accessing company data on their behalf is not allowed (Automated) 60
2.7 (L2) Ensure the admin consent workflow is enabled (Automated) 63
2.8 (L2) - Ensure users installing Outlook add-ins is not allowed (Automated) 65
2.9 (L1) - Ensure users installing Word, Excel, and PowerPoint add-ins is not allowed (Manual) 69
3 Data Management 71
3.1 (L2) Ensure the customer lockbox feature is enabled (Automated) 71
3.2 (L2) Ensure SharePoint Online data classification policies are set up and used (Manual) 74
3.3 (L2) Ensure external domains are not allowed in Skype or Teams (Manual) 76
3.4 (L1) Ensure DLP policies are enabled (Automated) 78
3.5 (L1) Ensure DLP policies are enabled for Microsoft Teams (Manual) 80

ARCHIVE

3.6 (L2) Ensure that external users cannot share files, folders, and sites they do not own (Automated) 82
3.7 (L2) Ensure external file sharing in Teams is enabled for only approved cloud storage services (Manual) 84
4 Email Security / Exchange Online 88
4.1 (L1) Ensure the Common Attachment Types Filter is enabled (Automated) 88
4.3 (L1) Ensure mail transport rules do not forward email to external domains (Automated) 93
4.4 (L2) Ensure automatic forwarding options are disabled (Automated) 95
4.5 (L1) Ensure mail transport rules do not whitelist specific domains (Automated) 97
4.6 (L2) Ensure the Client Rules Forwarding Block is enabled (Automated) 99
4.7 (L2) Ensure the Advanced Threat Protection Safe Links policy is enabled (Automated) 101
4.8 (L2) Ensure the Advanced Threat Protection Safe Attachments policy is enabled (Automated) 104
4.9 (L2) Ensure basic authentication for Exchange Online is disabled (Automated) 106
4.10 (L1) Ensure that an anti-phishing policy has been created (Automated) 109
4.11 (L1) Ensure that DKIM is enabled for all Exchange Online Domains (Automated) 111
4.12 (L1) Ensure that SPF records are published for all Exchange Domains (Manual) 114
4.13 (L1) Ensure DMARC Records for all Exchange Online domains are published (Manual) 116
4.14 (L1) Ensure notifications for internal users sending malware is Enabled (Automated) 118
4.15 (L2) Ensure MailTips are enabled for end users (Automated) 120
4.16 (L2) Ensure that LinkedIn contact synchronization is disabled. (Automated) 122
5 Auditing 126
5.1 (L1) Ensure Microsoft 365 audit log search is Enabled (Automated) 126
5.2 (L1) Ensure mailbox auditing for all users is Enabled (Automated) 129

ARCHIVE

5.3 (L1) Ensure the Azure AD 'Risky sign-ins' report is reviewed at least weekly (Manual) 133
5.4 (L2) Ensure the Application Usage report is reviewed at least weekly (Manual) 135
5.5 (L1) Ensure the self-service password reset activity report is reviewed at least weekly (Manual) 136
5.6 (L1) Ensure user role group changes are reviewed at least weekly (Manual) 137
5.7 (L1) Ensure mail forwarding rules are reviewed at least weekly (Manual) 139
5.8 (L1) Ensure the Mailbox Access by Non-Owners Report is reviewed at least biweekly (Manual) 141
5.9 (L1) Ensure the Malware Detections report is reviewed at least weekly (Manual) 143
5.10 (L1) Ensure the Account Provisioning Activity report is reviewed at least weekly (Manual) 144
5.11 (L1) Ensure non-global administrator role group assignments are reviewed at least weekly (Manual) 146
5.12 (L1) Ensure the spoofed domains report is review weekly (Manual) 147
5.14 (L1) Ensure the report of users who have had their email privileges restricted due to spamming is reviewed (Manual) 151
5.15 (L1) Ensure Guest Users are reviewed at least biweekly (Manual) 152
6 Storage 154
6.1 (L2) Ensure document sharing is being controlled by domains with whitelist or blacklist (Automated) 154
6.2 (L2) Block OneDrive for Business sync from unmanaged devices (Automated) 156
6.4 (L2) Ensure external storage providers available in Outlook on the Web are restricted (Automated) 161
7 Mobile Device Management 163
7.1 (L1) Ensure mobile device management polices are set to require advanced security configurations to protect from basic internet attacks (Manual) 163
7.2 (L1) Ensure that mobile device password reuse is prohibited (Manual) 165
7.3 (L1) Ensure that mobile devices are set to never expire passwords (Manual) 167

ARCHIVE

7.4 (L1) Ensure that users cannot connect from devices that are jail broken or rooted (Manual) 169
7.5 (L2) Ensure mobile devices are set to wipe on multiple sign-in failures to prevent brute force compromise (Manual) 171
7.6 (L1) Ensure that mobile devices require a complex password to prevent brute force attacks (Manual) 173
7.7 (L1) Ensure that settings are enable to lock devices after a period of inactivity to prevent unauthorized access (Manual) 175
7.8 (L1) Ensure that mobile device encryption is enabled to prevent unauthorized access to mobile data (Manual) 177
7.9 (L1) Ensure that mobile devices require complex passwords (Type = Alphanumeric) (Manual) 179
7.10 (L1) Ensure that mobile devices require complex passwords (Simple Passwords = Blocked) (Manual) 181
7.11 (L1) Ensure that devices connecting have AV and a local firewall enabled (Manual) 183
7.12 (L2) Ensure mobile device management policies are required for email profiles (Manual) 185
7.13 (L1) Ensure mobile devices require the use of a password (Manual) 187
Appendix: Summary Table 189
Appendix: Change History 194

ARCHIVE

Overview

This document, Security Configuration Benchmark for Microsoft 365, provides prescriptive guidance for establishing a secure configuration posture for Microsoft 365 running on any OS. This guide was tested against Microsoft 365, and includes recommendations for Exchange Online, SharePoint Online, OneDrive for Business, Skype/Teams, Azure Active Directory, and inTune. To obtain the latest version of this guide, please visit http://cisecurity.org. If you have questions, comments, or have identified ways to improve this guide, please write us at feedback@cisecurity.org.

Intended Audience

This benchmark is intended for system and application administrators, security specialists, auditors, help desk, and platform deployment personnel who plan to develop, deploy, assess, or secure solutions that incorporate Microsoft 365.

Consensus Guidance

This benchmark was created using a consensus review process comprised of subject matter experts. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS benchmark undergoes two phases of consensus review. The first phase occurs during initial benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the benchmark. This discussion occurs until consensus has been reached on benchmark recommendations. The second phase begins after the benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the benchmark. If you are interested in participating in the consensus process, please visit https://workbench.cisecurity.org/.

ARCHIVE

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
`Stylized Monospace font`	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
Monospace font	Used for inline code, commands, or examples. Text should be interpreted exactly as presented.
<italic font in brackets>	Italic texts set in angle brackets denote a variable requiring substitution for a real value.
Italic font	Used to denote the title of a book, article, or other publication.
Note	Additional information or caveats

Assessment Status

An assessment status is included for every recommendation. The assessment status indicates whether the given recommendation can be automated or requires manual steps to implement. Both statuses are equally important and are determined and supported as defined below:

Automated

Represents recommendations for which assessment of a technical control can be fully automated and validated to a pass/fail state. Recommendations will include the necessary information to implement automation.

Manual

Represents recommendations for which assessment of a technical control cannot be fully automated and requires all or some manual steps to validate that the configured state is set as expected. The expected state can vary depending on the environment.

ARCHIVE

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **E3 Level 1**

  Items in this profile apply to customer deployments of Microsoft M365 with an E3 license and intend to:

  - be practical and prudent;
  - provide a clear security benefit; and
  - not inhibit the utility of the technology beyond acceptable means.

- **E3 Level 2**

  This profile extends the "E3 Level 1" profile. Items in this profile exhibit one or more of the following characteristics and is focused on customer deployments of Microsoft M365 E3:

  - are intended for environments or use cases where security is paramount
  - acts as defense in depth measure
  - may negatively inhibit the utility or performance of the technology.

- **E5 Level 1**

  Items in this profile extend what is provided by the "E3 Level 1" profile for customer deployments of Microsoft M365 with an E5 license and intend to:

  - be practical and prudent;
  - provide a clear security benefit; and
  - not inhibit the utility of the technology beyond acceptable means.

- **E5 Level 2**

  This profile extends the "E3 Level 1" and "E5 Level 1" profiles. Items in this profile exhibit one or more of the following characteristics and is focused on customer deployments of Microsoft M365 E5:

  - are intended for environments or use cases where security is paramount
  - acts as defense in depth measure
  - may negatively inhibit the utility or performance of the technology.

ARCHIVE

Acknowledgements

This benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

Contributor
Jordan Rakoske
Gururaj Pandurangi
Shamir Charania
Sean Sweeney
Karen Scarfone
Jon Wall
Himalay Kondekar
Eric Ibison
Patrick Benesch

Editor
Dan Menicucci
Brandon Cox
Phil White
Clifford Moten
Brian Greidanus
Wacey Lanier
Cody McLees

ARCHIVE

Recommendations

1 Account / Authentication

1.1 Azure Active Directory

Section on AAD as the underlying AuthN / AuthZ for SaaS

1.1.1 (L1) Ensure multifactor authentication is enabled for all users in administrative roles (Automated)

Profile Applicability:

- E3 Level 1

Description:

Enable multifactor authentication for all users who are members of administrative roles in the Microsoft 365 tenant. These include roles such as:

- Global Administrator
- Billing Administrator
- Exchange Administrator
- SharePoint Administrator
- Password Administrator
- Skype for Business Administrator
- Service Administrator
- User Management Administrator
- Dynamics 365 Service Administrator
- Power BI Administrator

Rationale:

Multifactor authentication requires an individual to present a minimum of two separate forms of authentication before access is granted. Multifactor authentication provides additional assurance that the individual attempting to gain access is who they claim to be. With multifactor authentication, an attacker would need to compromise at least two different authentication mechanisms, increasing the difficulty of compromise and thus reducing the risk.

ARCHIVE

Audit:

To verify the multifactor authentication configuration for administrators, use the Microsoft 365 Admin Center:

1. Log in to `https://admin.microsoft.com` as a `Global Administrator`.
2. Go to `Admin centers` and click on `Azure Active Directory`.
3. Select `Enterprise applications` then, under `Security`, select `Conditional Access`.
4. Review the list of policies and ensure that there is a policy that requires the `Grant` access control with `Require multi-factor authentication` for the appropriate `Directory roles` under `Users and groups`

To verify the multifactor authentication configuration for administrators, use the M365 SecureScore service:

1. Log in to the Secure Score portal (https://security.microsoft.com) using admin permissions (global admin or a custom admin role) for an Office 365 Enterprise, Microsoft 365 Business, or Office 365 Business Premium subscription.
2. Click on `Require MFA for Azure AD privileged roles` policy to check MFA for admin users.
3. It will show the number of Admin users who do not have MFA configured.

This information is also available via the Microsoft Graph Security API:

```
GET https://graph.microsoft.com/beta/security/secureScores
```

ARCHIVE

Remediation:

To enable multifactor authentication for administrators, use the Microsoft 365 Admin Center:

1. Log in to `https://admin.microsoft.com` as a `Global Administrator`.
2. Go to `Admin centers` and click on `Azure Active Directory`.
3. Select `Enterprise applications` then, under `Security`, select `Conditional Access`.
4. Click `New policy`
5. Go to `Assignments` > `Users and groups` > `Include` > `Select users and groups` > check `Directory roles`.
6. At a minimum, select the following roles: `Billing admin`, `Conditional Access admin`, `Exchange admin`, `Global admin`, `Helpdesk admin`, `Security admin`, `SharePoint admin`, and `User admin`.
7. Go to `Cloud apps or actions` > `Cloud apps` > `Include` > select `All cloud apps (and don't exclude any apps)`.
8. Under `Access controls` > `Grant` > select `Grant access` > check `Require multi-factor authentication` (and nothing else).
9. Leave all other conditions blank.
10. Make sure the policy is enabled.
11. Create.

Impact:

Implementation of multifactor authentication for all users in administrative roles will necessitate a change to user routine. All users in administrative roles will be required to enroll in multifactor authentication using using phone, SMS, or an authentication application. After enrollment, use of multifactor authentication will be required for future access to the environment.

References:

1. https://docs.microsoft.com/en-us/graph/api/resources/security-api-overview?view=graph-rest-beta

CIS Controls:

Version 7

16.3 Require Multi-factor Authentication

Require multi-factor authentication for all user accounts, on all systems, whether managed onsite or by a third-party provider.

ARCHIVE

1.1.2 (L2) Ensure multifactor authentication is enabled for all users in all roles (Manual)

Profile Applicability:

- E3 Level 2

Description:

Enable multifactor authentication for all users in the Microsoft 365 tenant. Users will be prompted to authenticate with a second factor upon logging in to Microsoft 365 services each day. The second factor is most commonly a text message to a registered mobile phone number where they type in an authorization code, or with a mobile application like Microsoft Authenticator.

Rationale:

Multifactor authentication requires an individual to present a minimum of two separate forms of authentication before access is granted. Multifactor authentication provides additional assurance that the individual attempting to gain access is who they claim to be. With multifactor authentication, an attacker would need to compromise at least two different authentication mechanisms, increasing the difficulty of compromise and thus reducing the risk.

Audit:

To verify the multifactor authentication configuration for all users, use the Microsoft 365 Admin Center:

1. Log in to `https://admin.microsoft.com` as a `Global Administrator`.
2. Go to `Admin centers` and click on `Azure Active Directory`.
3. Select `Enterprise applications` then, under `Security`, select `Conditional Access`.
4. Review the list of policies and ensure that there is a policy that requires the `Grant` access control with `Require multi-factor authentication` for `All users` under `Users and groups`

ARCHIVE

To verify the multifactor authentication configuration for administrators, use the M365 SecureScore service:

1. Log in to the Secure Score portal (https://security.microsoft.com) using admin permissions (global admin or a custom admin role) for an Office 365 Enterprise, Microsoft 365 Business, or Office 365 Business Premium subscription.
2. Click on `Require MFA for all users` policy to check MFA for all users.
3. It will show the number of users who do not have MFA configured.

This information is also available via the Microsoft Graph Security API:

```
GET https://graph.microsoft.com/beta/security/secureScores
```

Remediation:

To enable multifactor authentication for all users, use the Microsoft 365 Admin Center:

1. Log in to `https://admin.microsoft.com` as a `Global Administrator`.
2. Go to `Admin centers` and click on `Azure Active Directory`.
3. Select `Enterprise applications` then, under `Security`, select `Conditional Access`.
4. Click `New policy`
5. Select `Cloud apps or actions` > `All cloud apps` (and don't exclude any apps)
6. `Access Controls` > `Grant` > `Require multi-factor authentication` (and nothing else)
7. `Conditions` > `Client Apps` > `Configure` (Yes) > Explicitly select `Browser`, `Mobile apps and desktop clients`, `Modern authentication clients`, `Exchange ActiveSync clients`, and `Other clients`
8. Leave all other conditions blank
9. Make sure the policy is enabled
10. Create

ARCHIVE

Impact:

Implementation of multifactor authentication for all users will necessitate a change to user routine. All users will be required to enroll in multifactor authentication using using phone, SMS, or an authentication application. After enrollment, use of multifactor authentication will be required for future authentication to the environment.

Default Value:

Disabled

CIS Controls:

Version 7

16.3 Require Multi-factor Authentication

Require multi-factor authentication for all user accounts, on all systems, whether managed onsite or by a third-party provider.

ARCHIVE

1.1.3 (L1) Ensure that between two and four global admins are designated (Automated)

Profile Applicability:

- E3 Level 1

Description:

More than one global administrator should be designated so a single admin can be monitored and to provide redundancy should a single admin leave an organization. Additionally, there should be no more than four global admins set for any tenant.

Rationale:

If there is only one global tenant administrator, he or she can perform malicious activity without the possibility of being discovered by another admin. If there are numerous global tenant administrators, the more likely it is that one of their accounts will be successfully breached by an external attacker.

Audit:

To verify the number of global tenant administrators, use the Microsoft 365 Admin Center:

1. Log in to `https://admin.microsoft.com` as a `Global Administrator`.
2. Select `Users` > `Active Users`.
3. Select `Filter` then select `Global Admins`.
4. Review the list of `Global Admins` to confirm there are from two to four such accounts.

ARCHIVE

To verify the number of global tenant administrators, you can also use the Office 365 PowerShell MSOL:

1. Connect to Microsoft 365 using Connect-MSOLService
2. Run the following PowerShell commands:

```
$role = Get-MsolRole -RoleName "Company Administrator"
Get-MsolRoleMember -RoleObjectId $role.objectid
```

This information is also available via the Microsoft Graph Security API:

```
GET https://graph.microsoft.com/beta/security/secureScores
```

Remediation:

To correct the number of global tenant administrators, use the Microsoft 365 Admin Center:

1. Log in to `https://admin.microsoft.com` as a `Global Administrator`.
2. Select `Users` > `Active Users`.
3. In the `Search`field enter the name of the user to be made a Global Administrator.
4. To create a new Global Admin:
    1. Select the user's name.
    2. A window will appear to the right.
    3. Select `Manage roles`.
    4. Select `Admin center access`.
    5. Check `Global Administrator`.
    6. Click `Save changes`.
5. To remove Global Admins:
    1. Select User.
    2. Under `Roles` select `Manage roles`
    3. De-Select the appropriate role.
    4. Click `Save changes`.

ARCHIVE

To correct the number of global tenant administrators, you can also use the Office 365 PowerShell MSOL:

1. Connect to Microsoft 365 using Connect-MSOLService
2. Store the variables with the following Powershell

```
$dispName="<The Display Name of the account>"
$roleName="<The role name you want to assign to the account>"
```

3. Run the following PowerShell command:

```
Add-MsolRoleMember -RoleMemberEmailAddress (Get-MsolUser -All | Where
DisplayName -eq $dispName).UserPrincipalName -RoleName $roleName
```

Impact:

The potential impact associated with ensuring compliance with this requirement is dependent upon the current number of global administrators configured in the tenant. If there is only one global administrator in a tenant, an additional global administrator will need to be identified and configured. If there are more than four global administrators, a review of role requirements for current global administrators will be required to identify which of the users require global administrator access.

References:

1. https://docs.microsoft.com/en-us/office365/enterprise/powershell/assign-roles-to-user-accounts-with-office-365-powershell

CIS Controls:

Version 7

4.1 Maintain Inventory of Administrative Accounts

Use automated tools to inventory all administrative accounts, including domain and local accounts, to ensure that only authorized individuals have elevated privileges.

ARCHIVE

1.1.4 (L1) Ensure self-service password reset is enabled (Automated)

Profile Applicability:

- E3 Level 1

Description:

Enabling self-service password reset allows users to reset their own passwords in Azure AD. When your users sign in to Microsoft 365, they will be prompted to enter additional contact information that will help them reset their password in the future.

Rationale:

Users will no longer need to engage the helpdesk for password resets, and the password reset mechanism will automatically block common, easily guessable passwords.

Audit:

To verify self-service password reset is enabled, use the Microsoft 365 Admin Center:

1. Under `Admin centers` choose `Azure Active Directory`.
2. Choose `Users` from the left hand navigation.
3. Choose `Password reset`.
4. On the Properties page, ensure that `All` is selected under `Self service password reset enabled`.

This information is also available via the Microsoft Graph Security API:

```
GET https://graph.microsoft.com/beta/security/secureScores
```

Remediation:

To enable self-service password reset, use the Microsoft 365 Admin Center:

1. Under `Admin centers` choose `Azure Active Directory`.
2. Choose `Users` from the left hand navigation.
3. Choose `Password reset`.
4. On the Properties page, select `All` under `Self service password reset enabled`.
5. Select `Save`.

ARCHIVE

Impact:

The impact associated with this setting is that users will be required to provide additional contact information to enroll in self-service password reset. Additionally, minor user education may be required for users that are used to calling a help desk for assistance with password resets.

References:

1. https://support.office.com/en-us/article/let-users-reset-their-own-passwords-in-office-365-5bc3f460-13cc-48c0-abd6-b80bae72d04a
2. https://gallery.technet.microsoft.com/office/Enable-Self-Service-59846d88
3. https://docs.microsoft.com/en-us/azure/active-directory/authentication/quickstart-sspr

CIS Controls:

Version 7

16.2 Configure Centralized Point of Authentication

Configure access for all accounts through as few centralized points of authentication as possible, including network, security, and cloud systems.

ARCHIVE

1.1.5 (L1) Ensure that password protection is enabled for Active Directory (Manual)

Profile Applicability:

- E3 Level 1

Description:

Enable Azure Active Directory Password Protection to Active Directory to protect against the use of common passwords.

Rationale:

Azure Active Directory protects an organization by prohibiting the use of weak or leaked passwords. In addition, organizations can create custom banned password lists to prevent their users from using easily guessed passwords that are specific to their industry. Deploying this feature to Active Directory will strengthen the passwords that are used in the environment.

Audit:

To verify that Azure Active Directory Password Protection is enabled, use the Microsoft 365 Admin Center:

1. Log in to `https://admin.microsoft.com` as a `Global Administrator`.
2. Go to `Admin centers` and click on `Azure Active Directory`.
3. Select `Azure Active Directory` then `Security` on the left side navigation followed by `Authentication methods`.
4. Select `Password protection` and ensure that `Enable password protection on Windows Server Active Directory` is set to `Yes` and also that `Mode` is set to `Enforced`
5. Verify that the Domain Controller Agent and Proxy's are deployed to the Domain Controllers in the environment

ARCHIVE

Remediation:

To setup Azure Active Directory Password Protection, use the following steps:

1. Download and install the `Azure AD Password Proxies` and `DC Agents` from the following location: https://www.microsoft.com/download/details.aspx?id=57071
2. After the installation is complete, login to `https://admin.microsoft.com` as a `Global Administrator`.
3. Go to `Admin centers` and click on `Azure Active Directory`.
4. Select `Azure Active Directory` then `Security` on the left side navigation followed by `Authentication methods`.
5. Select `Password protection` and toggle `Enable password protection on Windows Server Active Directory` to `Yes` and `Mode` to `Enforced`
6. Click Save at the top of the right pane.

Impact:

The potential impact associated with implementation of this setting is dependent upon the existing password policies in place in the environment. For environments that have strong password policies in place, the impact will be minimal. For organizations that do not have strong password policies in place, implementation of Azure Active Directory Password Protection may require users to change passwords, and adhere to more stringent requirements than they have been accustomed to.

CIS Controls:

Version 7

4.4 Use Unique Passwords

Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.

ARCHIVE

1.1.6 (L1) Enable Conditional Access policies to block legacy authentication (Automated)

Profile Applicability:

- E3 Level 1

Description:

Use Conditional Access to block legacy authentication protocols in Office 365.

Rationale:

Legacy authentication protocols do not support multi-factor authentication. These protocols are often used by attackers because of this deficiency. Blocking legacy authentication makes it harder for attackers to gain access.

Audit:

To verify that legacy authentication is blocked, use the Microsoft 365 Admin Center:

1. Log in to `https://admin.microsoft.com` as a `Global Administrator`.
2. Go to `Admin centers` and click on `Azure Active Directory`.
3. Select `Azure Active Directory` then `Security`.
4. Select `Conditional Access`.
5. Verify that either the policy `Baseline policy: Block legacy authentication (Preview)` is set to On or find another with the following settings enabled:
    - Under `Client apps (preview)` ensure that `Mobile apps and desktop clients` and `Other clients` are checked
    - Under `Access controls` the `Grant` is set to `Block access`
    - Under `Assignments` that `All users` and `All cloud apps` are selected

This information is also available via the Microsoft Graph Security API:

```
GET https://graph.microsoft.com/beta/security/secureScores
```

ARCHIVE

Remediation:

To setup a conditional access policy to block legacy authentication, use the following steps:

1. Log in to `https://admin.microsoft.com` as a `Global Administrator`.
2. Go to `Admin centers` and click on `Azure Active Directory`.
3. Select `Azure Active Directory` then `Security`.
4. Select `Conditional Access`.
5. Create a new policy by selecting `New policy`.
6. Set the following conditions within the policy.
    - Select `Conditions` then under `Client apps (preview)` enable the settings for `Mobile apps and desktop clients` and `Other clients`
    - Under `Access controls` set the `Grant` section to `Block access`
    - Under `Assignments` enable `All users` and `All cloud apps`
    - Under `Assignments` and `Users and groups` set the `Exclude` to be at least one low risk account or directory role. This is required as a best practice.

Impact:

Enabling this setting will prevent users from connecting with older versions of Office, ActiveSync or using protocols like IMAP, POP or SMTP and may require upgrades to older versions of Office, and use of mobile mail clients that support modern authentication.

Default Value:

Legacy authentication is enabled by default.

CIS Controls:

Version 7

9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u>
Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.

ARCHIVE

1.1.7 (L1) Ensure that password hash sync is enabled for resiliency and leaked credential detection (Manual)

Profile Applicability:

- E3 Level 1

Description:

Ensure that password hash sync is enabled for resiliency and leaked credential detection.

Rationale:

Password hash synchronization is one of the sign-in methods used to accomplish hybrid identity. Azure AD Connect synchronizes a hash, of the hash, of a user's password from an on-premises Active Directory instance to a cloud-based Azure AD instance. Password hash synchronization helps by reducing the number of passwords your users need to maintain to just one. Enabling password hash synchronization also allows for leaked credential reporting. It can also be used as a backup authentication method when federation is used, if the federation provider fails.

Audit:

To verify if Password Hash Sync is enabled, use the Azure AD Connect tool:

1. Log in to the server that hosts the Azure AD Connect tool
2. Run `Azure AD Connect`, and then click `View current configuration`. In the details pane, check whether Password synchronization is enabled on your tenant.

This information is also available via the Microsoft Graph Security API:

```
GET https://graph.microsoft.com/beta/security/secureScores
```

ARCHIVE

Remediation:

To setup Password Hash Sync, use the following steps:

1. Log in to the server that hosts the Azure AD Connect tool
2. Double-click the `Azure AD Connect` icon that was created on the desktop
3. Click `Configure`.
4. On the `Additional tasks` page, select `Customize synchronization options` and click `Next`.
5. Enter the username and password for your global administrator.
6. On the `Connect your directories` screen, click `Next`.
7. On the `Domain and OU filtering` screen, click `Next`.
8. On the `Optional features` screen, check `Password hash synchronization` and click `Next`.
9. On the `Ready to configure` screen click `Configure`.
10. Once the configuration completes, click `Exit`.

Impact:

Enabling password hash sync should not impact end users.

CIS Controls:

Version 7

16.4 <u>Encrypt or Hash all Authentication Credentials</u>
Encrypt or hash with a salt all authentication credentials when stored.

ARCHIVE

1.1.8 (L1) Enabled Identity Protection to identify anomalous logon behavior (Manual)

Profile Applicability:

- E5 Level 1

Description:

Azure Active Directory Identity Protection monitors account behaviors and enables organizations to configure automated responses to detected suspicious actions related to user identities.

Rationale:

Azure Active Directory Identity Protection helps to discover at risk or compromised accounts in your environment. Identity based attacks continue to be a top source for breaches. Enabling Identity Protection not only helps to monitor and provide reporting, but also helps to automatically respond to identity based risks.

Audit:

To verify if Azure Active Directory Identity Protection is enabled, use the following steps:

1. Sign-on to your Azure portal as global administrator by going to `https://portal.azure.com`
2. In the Azure portal, click `Marketplace`.
3. In the applications list, click `Identity`.
4. Click `Azure AD Identity Protection`.
5. On the `Azure AD Identity Protection` blade, validate that the feature has been enabled.

ARCHIVE

Remediation:

To setup Azure Active Directory Identity Protection, use the following steps:

1. Sign-on to your Azure portal as global administrator by going to `https://portal.azure.com`
2. In the Azure portal, click `Marketplace`.
3. In the applications list, click `Identity`.
4. Click `Azure AD Identity Protection`.
5. On the `Azure AD Identity Protection` blade, click `Create`.

Impact:

The impacts associated with implementation of this setting are highly dependent upon the specific response actions configured in Identity Protection.

CIS Controls:

Version 7

16.13 Alert on Account Login Behavior Deviation
Alert when users deviate from normal login behavior, such as time-of-day, workstation location and duration.

ARCHIVE

1.1.9 (L2) Enable Azure AD Identity Protection sign-in risk policies (Manual)

Profile Applicability:

- E5 Level 2

Description:

Azure Active Directory Identity Protection sign-in risk detects risks in real-time and offline. A risky sign-in is an indicator for a sign-in attempt that might not have been performed by the legitimate owner of a user account.

Rationale:

Turning on the sign-in risk policy ensures that suspicious sign-ins are challenged for multi-factor authentication.

Audit:

To verify if a Sign-In risk policy is enabled, use the following steps:

1. Sign-on to your Azure portal as global administrator by going to `https://portal.azure.com`
2. In the Azure portal, click `Services` and search for and click on `Azure AD Identity Protection`.
3. Under `Configure` click on `Sign-in risk policy`.
4. Review the settings and ensure that `Enforce Policy` is set to `On`

This information is also available via the Microsoft Graph Security API:

```
GET https://graph.microsoft.com/beta/security/secureScores
```

ARCHIVE

Remediation:

To configure a Sign-In risk policy, use the following steps:

1. Sign-on to your Azure portal as global administrator by going to `https://portal.azure.com`
2. In the Azure portal, click `Services` and search for and click on `Azure AD Identity Protection`.
3. Under `Configure` click on `Sign-in risk policy`.
4. Under `Assignments` ensure that policy is applied to `All users` or the scope of users appropriate
5. Under `Assignments` choose `Conditions` and the appropriate `Sign-in risk` level
6. Under `Controls`, select `Access` and choose `Allow access` and `Require multi-factor authentication`
7. Ensure that `Enforce Policy` is set to `On`

Impact:

When the policy triggers, the user will need MFA to access the account. In the case of a user who hasn't registered MFA on their account, they would be blocked from accessing their account. It is therefore recommended that the MFA registration policy be configured for all users who are a part of the Sign-in Risk policy.

CIS Controls:

Version 7

16.13 Alert on Account Login Behavior Deviation

Alert when users deviate from normal login behavior, such as time-of-day, workstation location and duration.

ARCHIVE

1.1.10 (L2) Enable Azure AD Identity Protection user risk policies (Manual)

Profile Applicability:

- E5 Level 2

Description:

Azure Active Directory Identity Protection user risk policies detect the probability that a user account has been compromised.

Rationale:

With the user risk policy turned on, Azure AD detects the probability that a user account has been compromised. As an administrator, you can configure a user risk conditional access policy to automatically respond to a specific user risk level. For example, you can block access to your resources or require a password change to get a user account back into a clean state.

Audit:

To verify if a User Risk policy is enabled, use the following steps:

1. Sign-on to your Azure portal as global administrator by going to `https://portal.azure.com`
2. In the Azure portal, click `Services` and search for and click on `Azure AD Identity Protection`.
3. Under `Configure` click on `User risk policy`.
4. Review the settings and ensure that `Enforce Policy` is set to `On`

This information is also available via the Microsoft Graph Security API:

```
GET https://graph.microsoft.com/beta/security/secureScores
```

ARCHIVE

Remediation:

To configure a User risk policy, use the following steps:

1. Sign-on to your Azure portal as global administrator by going to `https://portal.azure.com`
2. In the Azure portal, click `Services` and search for and click on `Azure AD Identity Protection`.
3. Under `Configure` click on `User risk policy`.
4. Under `Assignments` ensure that policy is applied to `All users` or the scope of users appropriate
5. Under `Assignments` choose `Conditions` and the appropriate `User risk` level
6. Under `Controls`, select `Access` and choose `Allow access` and `Require password change`
7. Ensure that `Enforce Policy` is set to `On`

Impact:

When the policy triggers, access to the account will either be blocked or the user would be required to use multi-factor authentication and change their password. Users who haven't registered MFA on their account will be blocked from accessing it. If account access is blocked, an admin would need to recover the account. It is therefore recommended that the MFA registration policy be configured for all users who are a part of the User Risk policy.

CIS Controls:

Version 7

16.13 Alert on Account Login Behavior Deviation

Alert when users deviate from normal login behavior, such as time-of-day, workstation location and duration.

ARCHIVE

1.1.11 (L2) Use Just In Time privileged access to Office 365 roles (Manual)

Profile Applicability:

- E5 Level 2

Description:

Azure Active Directory Privileged Identity Management can be used to audit roles, allow just in time activation of roles and allow for periodic role attestation. Organizations should remove permanent members from privileged Office 365 roles and instead make them eligible, through a JIT activation workflow.

Rationale:

Organizations want to minimize the number of people who have access to secure information or resources, because that reduces the chance of a malicious actor getting that access, or an authorized user inadvertently impacting a sensitive resource. However, users still need to carry out privileged operations in Azure AD and Office 365. Organizations can give users just-in-time (JIT) privileged access to roles. There is a need for oversight for what those users are doing with their administrator privileges. PIM helps to mitigate the risk of excessive, unnecessary, or misused access rights.

ARCHIVE

Audit:

To verify if Privileged Identity Management is being used for Role activation, use the following steps:

1. Sign-on to your Azure portal as global administrator by going to `https://portal.azure.com`
2. In the Azure portal, click `Services` and search for and click on `Azure AD Privileged Identity management`.
3. Under `Manage` click on `Azure AD Roles`.
4. Under `Manage` click on `Roles`.
5. Inspect the following sensitive roles to ensure that the members are `Eligible` and not `Permanent`:
```
Application Administrator
Authentication Administrator
Billing Administrator
Cloud Application Administrator
Cloud Device Administrator
Compliance Administrator
Customer LockBox Access Approver
Device Administrators
Exchange Administrators
Global Administrators
HelpDesk Administrator
Information Protection Administrator
Intune Service Administrator
Kaizala Administrator
License Administrator
Password Administrator
PowerBI Service Administrator
Privileged Authentication Administrator
Privileged Role Administrator
Security Administrator
SharePoint Service Administrator
Skype for Business Administrator
Teams Service Administrator
User Administrator
```

ARCHIVE

Remediation:

To configure sensitive Azure AD roles for Privileged Identity Management Role activation, use the following steps:

1. Sign-on to your Azure portal as global administrator by going to `https://portal.azure.com`
2. In the Azure portal, click `Services` and search for and click on `Azure AD Privileged Identity management`.
3. Under `Manage` click on `Azure AD Roles`.
4. Under `Manage` click on `Roles`.
5. Inspect the following sensitive roles. For each of the members that have an `ASSIGNMENT TYPE` of `Permanent`, click on the . . . and choose `Make eligible`:
   `Application Administrator`
   `Authentication Administrator`
   `Billing Administrator`
   `Cloud Application Administrator`
   `Cloud Device Administrator`
   `Compliance Administrator`
   `Customer LockBox Access Approver`
   `Device Administrators`
   `Exchange Administrators`
   `Global Administrators`
   `HelpDesk Administrator`
   `Information Protection Administrator`
   `Intune Service Administrator`
   `Kaizala Administrator`
   `License Administrator`
   `Password Administrator`
   `PowerBI Service Administrator`
   `Privileged Authentication Administrator`
   `Privileged Role Administrator`
   `Security Administrator`
   `SharePoint Service Administrator`
   `Skype for Business Administrator`
   `Teams Service Administrator`
   `User Administrator`

ARCHIVE

Impact:

Implementation of Just in Time privileged access is likely to necessitate changes to administrator routine. Administrators will only be granted access to administrative roles when required. When administrators request role activation, they will need to document the reason for requiring role access, anticipated time required to have the access, and to reauthenticate to enable role access.

CIS Controls:

Version 7

4.1 Maintain Inventory of Administrative Accounts

Use automated tools to inventory all administrative accounts, including domain and local accounts, to ensure that only authorized individuals have elevated privileges.

ARCHIVE

1.1.12 (L1) Ensure Security Defaults is disabled on Azure Active Directory (Manual)

Profile Applicability:

- E3 Level 1

Description:

Security defaults in Azure Active Directory (Azure AD) make it easier to be secure and help protect your organization. Security defaults contain preconfigured security settings for common attacks.

Microsoft is making security defaults available to everyone. The goal is to ensure that all organizations have a basic level of security-enabled at no extra cost. You turn on security defaults in the Azure portal.

The use of Security Defaults however will prohibit custom settings which are being set with more advanced settings from this benchmark

Rationale:

Security defaults provide secure default settings that we manage on behalf of organizations to keep customers safe until they are ready to manage their own identity security story.

For starters, we're doing the following:

- Requiring all users and admins to register for MFA.
- Challenging users with MFA - mostly when they show up on a new device or app, but more often for critical roles and tasks.
- Disabling authentication from legacy authentication clients, which can't do MFA.

Audit:

To ensure security defaults is disabled in your directory:

1. Sign in to the Azure portal as a security administrator, Conditional Access administrator, or global administrator.
2. Browse to Azure Active Directory > Properties.
3. Select Manage security defaults.
4. Verify the Enable security defaults toggle to `No`.

ARCHIVE

Remediation:

To disable security defaults in your directory:

1. Sign in to the Azure portal as a security administrator, Conditional Access administrator, or global administrator.
2. Browse to Azure Active Directory > Properties.
3. Select Manage security defaults.
4. Set the Enable security defaults toggle to No.
5. Select Save.

Impact:

The potential impact associated with disabling of Security Defaults is dependent upon the security controls implemented in the environment. It is likely that most organizations disabling Security Defaults plan to implement equivalent controls to replace Security Defaults.

References:

1. https://docs.microsoft.com/en-us/azure/active-directory/fundamentals/concept-fundamentals-security-defaults
2. https://techcommunity.microsoft.com/t5/azure-active-directory-identity/introducing-security-defaults/ba-p/1061414

CIS Controls:

Version 7

5.1 Establish Secure Configurations

Maintain documented, standard security configuration standards for all authorized operating systems and software.

ARCHIVE

1.2 (L1) Ensure modern authentication for Exchange Online is enabled (Automated)

Profile Applicability:

- E3 Level 1

Description:

Modern authentication in Microsoft 365 enables authentication features like multifactor authentication (MFA) using smart cards, certificate-based authentication (CBA), and third-party SAML identity providers. When you enable modern authentication in Exchange Online, Outlook 2016 and Outlook 2013 use modern authentication to log in to Microsoft 365 mailboxes. When you disable modern authentication in Exchange Online, Outlook 2016 and Outlook 2013 use basic authentication to log in to Microsoft 365 mailboxes.

When users initially configure certain email clients, like Outlook 2013 and Outlook 2016, they may be required to authenticate using enhanced authentication mechanisms, such as multifactor authentication. Other Outlook clients that are available in Microsoft 365 (for example, Outlook Mobile and Outlook for Mac 2016) always use modern authentication to log in to Microsoft 365 mailboxes.

Rationale:

Strong authentication controls, such as the use of multifactor authentication, may be circumvented if basic authentication is used by Exchange Online email clients such as Outlook 2016 and Outlook 2013. Enabling modern authentication for Exchange Online ensures strong authentication mechanisms are used when establishing sessions between email clients and Exchange Online.

ARCHIVE

Audit:

To verify modern authentication is enabled, use the Exchange Online PowerShell Module:

1. Run the Microsoft Exchange Online PowerShell Module.
2. Connect to Exchange Online using `Connect-EXOPSSession`.
3. Run the following PowerShell command:

```
Get-OrganizationConfig | Format-Table -Auto Name, OAuth*
```

4. Verify `OAuth2ClientProfileEnabled` is `True`.

Remediation:

To enable modern authentication, use the Exchange Online PowerShell Module:

1. Run the Microsoft Exchange Online PowerShell Module.
2. Connect to Exchange Online using `Connect-EXOPSSession`.
3. Run the following PowerShell command:

```
Set-OrganizationConfig -OAuth2ClientProfileEnabled $True
```

Impact:

Users of older email clients, such as Outlook 2013 and Outlook 2016, will no longer be able to authenticate to Exchange using Basic Authentication, which will necessitate migration to modern authentication practices.

Default Value:

True

ARCHIVE

References:

1. https://support.office.com/en-gb/article/enable-or-disable-modern-authentication-in-exchange-online-58018196-f918-49cd-8238-56f57f38d662

CIS Controls:

Version 7

16.3 Require Multi-factor Authentication

Require multi-factor authentication for all user accounts, on all systems, whether managed onsite or by a third-party provider.

16.5 Encrypt Transmittal of Username and Authentication Credentials

Ensure that all account usernames and authentication credentials are transmitted across networks using encrypted channels.

ARCHIVE

1.3 (L1) Ensure modern authentication for Skype for Business Online is enabled (Automated)

Profile Applicability:

- E3 Level 1

Description:

Modern authentication in Microsoft 365 enables authentication features like multifactor authentication (MFA) using smart cards, certificate-based authentication (CBA), and third-party SAML identity providers. When you enable modern authentication in Skype for Business, the Skype for Business client uses modern authentication to log in to Skype for Business Online.

Rationale:

Strong authentication controls, such as the use of multifactor authentication, may be circumvented if basic authentication is used by Skype for Business Online clients. Enabling modern authentication for Skype for Business Online ensures strong authentication mechanisms are used when establishing sessions between clients and Skype for Business Online.

Audit:

To verify modern authentication is enabled, use the Skype for Business Online PowerShell Module:

1. Connect to Skype for Business Online using the following Powershell commands:

```
Import-Module SkypeOnlineConnector
$sfbSession = New-CsOnlineSession
Import-PSSession $sfbSession
```

2. Run the following PowerShell command to verify that modern authentication is enabled:

```
Get-CsOAuthConfiguration |fl ClientAdalAuthOverride
```

3. Verify that `ClientAdalAuthOverride` is set to `Allowed`.

ARCHIVE

Remediation:

To enable modern authentication, use the Skype for Business Online PowerShell Module:

1. Connect to Skype for Business Online using the following Powershell commands:

```
Import-Module SkypeOnlineConnector
$sfbSession = New-CsOnlineSession
Import-PSSession $sfbSession
```

2. Run the following PowerShell command to verify that modern authentication is enabled:

```
Set-CsOAuthConfiguration -ClientAdalAuthOverride Allowed
```

Impact:

Implementation of modern authentication for Skype of Business Online will require users to authenticate to Skype for Business Online using modern authentication. This may cause a minor impact to typical user behavior.

References:

1. https://social.technet.microsoft.com/wiki/contents/articles/34339.skype-for-business-online-enable-your-tenant-for-modern-authentication.aspx

CIS Controls:

Version 7

16.3 Require Multi-factor Authentication

Require multi-factor authentication for all user accounts, on all systems, whether managed onsite or by a third-party provider.

ARCHIVE

1.4 (L1) Ensure modern authentication for SharePoint applications is required (Automated)

Profile Applicability:

- E3 Level 1

Description:

Modern authentication in Microsoft 365 enables authentication features like multifactor authentication (MFA) using smart cards, certificate-based authentication (CBA), and third-party SAML identity providers

Rationale:

Strong authentication controls, such as the use of multifactor authentication, may be circumvented if basic authentication is used by SharePoint applications. Requiring modern authentication for SharePoint applications ensures strong authentication mechanisms are used when establishing sessions between these applications, SharePoint, and connecting users.

Audit:

To verify SharePoint settings, use the Microsoft 365 Admin Center:

1. Under `Admin centers` select `SharePoint`.
2. Expand the `Policies` section then select `Access Control`.
3. Select `Apps that don't use modern authentication` and ensure that it is set to `Block`.

To verify Apps that don't use modern authentication is set to Block, use the SharePoint Online PowerShell Module:

1. Connect to SharePoint Online using `Connect-SPOService -Url https://tenant-admin.sharepoint.com` replacing tenant with your value.
2. Run the following Sharepoint Online PowerShell command:

```
Get-SPOTenant | ft LegacyAuthProtocolsEnabled
```

3. Verify `LegacyAuthProtocolsEnabled` is set False

ARCHIVE

Remediation:

To set SharePoint settings, use the Microsoft 365 Admin Center:

1. Under `Admin centers` select `SharePoint`.
2. Expand the `Policies` section then select `Access Control`.
3. Select `Apps that don't use modern authentication`
4. Select the radio button for `Block`.
5. Click `OK`.

To set Apps that don't use modern authentication is set to Block, use the SharePoint Online PowerShell Module:

1. Connect to SharePoint Online using `Connect-SPOService -Url https://tenant-admin.sharepoint.com` replacing tenant with your value.
2. Run the following Sharepoint Online PowerShell command:

```
Set-SPOTenant -LegacyAuthProtocolsEnabled $false
```

Impact:

Implementation of modern authentication for SharePoint will require users to authenticate to SharePoint using modern authentication. This may cause a minor impact to typical user behavior.

CIS Controls:

Version 7

16.3 Require Multi-factor Authentication

Require multi-factor authentication for all user accounts, on all systems, whether managed onsite or by a third-party provider.

ARCHIVE

1.5 (L1) Ensure that Office 365 Passwords Are Not Set to Expire (Automated)

Profile Applicability:

- E3 Level 1

Description:

Review the password expiration policy, to ensure that user passwords in Office 365 are not set to expire.

Rationale:

NIST has updated their password policy recommendations to not arbitrarily require users to change their passwords after a specific amount of time, unless there is evidence that the password is compromised or the user forgot it. They suggest this even for single factor (Password Only) use cases, with a reasoning that forcing arbitrary password changes on users actually make the passwords less secure. Other recommendations within this Benchmark suggest the use of MFA authentication for at critical accounts (at minimum), which makes password expiration even less useful as well as password protection for Azure AD.

Audit:

To verify Office 365 Passwords Are Not Set to Expire, use the Microsoft 365 Admin Center:

1. Expand `Settings` then select the `Settings` subcategory.
2. Click on `Security & Privacy`.
3. Select `Password expiration policy` ensure that the `Set user passwords to expire after a number of days` is not checked.

To verify Office 365 Passwords Are Not Set to Expire, use the Microsoft Online PowerShell Module:

1. Connect to Microsoft Online service using `Connect-MSOLService`.
2. Run the following Microsoft Online PowerShell command:

```
Get-MsolPasswordPolicy -DomainName <DomainName> | ft ValidityPeriod
```

ARCHIVE

Remediation:

To set Office 365 Passwords to Expire, use the Microsoft 365 Admin Center:

1. Expand `Settings` then select the `Settings` subcategory.
2. Click on `Security & Privacy`.
3. Select `Password expiration policy`.
4. If the `Set user passwords to expire after a number of days` box is checked, uncheck it.
5. Click `Save changes`.

To set Office 365 Passwords Are Not Set to Expire, use the Microsoft Online PowerShell Module:

1. Connect to Microsoft Online service using `Connect-MSOLService`.
2. Run the following Microsoft Online PowerShell command:

```
Set-MsolPasswordPolicy -ValidityPeriod 2147483647 -DomainName <DomainName> -
NotificationDays 30
```

Impact:

The primary impact associated with this change is ensuring that users understand the process for making or requesting a password change when required.

References:

1. https://pages.nist.gov/800-63-3/sp800-63b.html

CIS Controls:

Version 7

4.4 Use Unique Passwords

Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.

ARCHIVE

2 Application Permissions

2.1 (L2) Ensure third party integrated applications are not allowed (Manual)

Profile Applicability:

- E3 Level 2

Description:

Do not allow third party integrated applications to connect to your services.

Rationale:

You should not allow third party integrated applications to connect to your services unless there is a very clear value and you have robust security controls in place. While there are legitimate uses, attackers can grant access from breached accounts to third party applications to exfiltrate data from your tenancy without having to maintain the breached account.

Audit:

To verify that third party integrated applications are not allowed, use the Microsoft 365 Admin Center:

1. Select `Admin Centers` and `Azure Active Directory`.
2. Select `Users` from the Azure navigation pane
3. Select `Users Settings`.
4. Verify `App Registrations` is set to `No`.

Remediation:

To prohibit third party integrated applications, use the Microsoft 365 Admin Center:

1. Select `Admin Centers` and `Azure Active Directory`.
2. Select `Users` from the Azure navigation pane
3. Select `Users Settings`.
4. Set `App Registrations` is set to `No`.

ARCHIVE

Impact:

Implementation of this change will impact both end users and administrators. End users will not be able to integrate third-party applications that they may wish to use. Administrators are likely to receive requests from end users to grant them permission to necessary third-party applications.

Default Value:

Yes

CIS Controls:

Version 7

18.4 Only Use Up-to-date And Trusted Third-Party Components

Only use up-to-date and trusted third-party components for the software developed by the organization.

ARCHIVE

2.2 (L2) Ensure calendar details sharing with external users is disabled (Automated)

Profile Applicability:

- E3 Level 2

Description:

You should not allow your users to share the full details of their calendars with external users.

Rationale:

Attackers often spend time learning about your organization before launching an attack. Publicly available calendars can help attackers understand organizational relationships and determine when specific users may be more vulnerable to an attack, such as when they are traveling.

Audit:

To verify calendar details sharing with external users is disabled, use the Microsoft 365 Admin Center:

1. Select `Admin Center` and Click to expand `Settings`.
2. Click `Settings`.
3. Click `Calendar`.
4. Verify `Let your users share their calendars with external users who have O365 or Exchange` is set to `Off` or unchecked.

To verify calendar details sharing with external users is disabled, use the Exchange Online PowerShell Module:

1. Connect to Exchange Online using `Connect-EXOPSSession`.
2. Run the following Exchange Online PowerShell command:

```
Get-SharingPolicy | Where-Object { $_.Domains -like '*CalendarSharing*' }
```

3. Verify `Enabled` is set to `False`

ARCHIVE

Remediation:

To disable calendar details sharing with external users, use the Microsoft 365 Admin Center:

1. Select `Admin Center` and Click to expand `Settings`.
2. Click `Settings`.
3. Click `Calendar`.
4. Set `Let your users share their calendars with external users who have O365 or Exchange` to `Off` or unchecked.
5. Click `Save`.

To disabled calendar details sharing with external users policy, use the Exchange Online PowerShell Module:

1. Connect to Exchange Online using `Connect-EXOPSSession`.
2. Run the following Exchange Online PowerShell command:

```
Set-SharingPolicy -Identity "Name of the policy" -Enabled $False
```

Impact:

This functionality is not widely used. As a result, it is unlikely that implementation of this setting will cause an impact to most users. Users that do utilize this functionality are likely to experience a minor inconvenience when scheduling meetings or synchronizing calendars with people outside the tenant.

Default Value:

On

CIS Controls:

Version 7

14.6 Protect Information through Access Control Lists

Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.

ARCHIVE

2.3 (L2) Ensure O365 ATP SafeLinks for Office Applications is Enabled (Automated)

Profile Applicability:

- E5 Level 2

Description:

Enabling the Advanced Threat Protection (ATP) Safe Links policy for Office applications allows URL's that existing inside of Office documents opened by Office, Office Online and Office mobile to be processed against ATP time-of-click verification.

Rationale:

ATP Safe Links for Office applications extends phishing protection to documents that contain hyperlinks, even after they have been delivered to a user.

Audit:

To verify the ATP Safe Links policy for Office is enabled, use the Microsoft 365 Admin Center:

1. Under `Admin centers` click `Security`.
2. Navigate to `Threat management` and select `Policy`
3. Select `ATP Safe Links`
4. Under `Policies that apply to the entire organization`, click on the `Default` policy and click `Edit`.
5. Under `Settings that apply to content except email`:
    1. Verify that `Office 365` is `checked` under `Use safe links in:`.
    2. Verify that `Do not let users click through safe links to original URL` is `checked`.

ARCHIVE

To verify the ATP Safe Links policy is enabled, use the Exchange Online PowerShell Module:

1. Connect using `Connect-EXOPSSession`.
2. Run the following PowerShell command:

```
Get-AtpPolicyForO365 | fl
Name,AllowClickThrough,EnableSafeLinksForClients,EnableSafeLinksForWebAccessC
ompanion,EnableSafeLinksForO365Clients
```

3. Verify the value for `AllowClickThrough` is set to `False` and the rest are set for `True`.

Remediation:

To enable the ATP Safe Links policy for Office, use the Microsoft 365 Admin Center:

1. Under `Admin centers` click `Security`.
2. Navigate to `Threat management` and select `Policy`
3. Select `ATP Safe Links`
4. Under `Policies that apply to the entire organization`, click on the `Default` policy and click `Edit`.
5. Under `Settings that apply to content except email`:
    1. Ensure that `Office 365` is `checked` under `Use safe links in:`.
    2. Ensure that `Do not let users click through safe links to original URL` is `checked`.
6. Select `Save`

To enable the ATP Safe Links policy for Office 365, use the Exchange Online PowerShell Module:

1. Connect using `Connect-EXOPSSession`.
2. Run the following PowerShell command:

```
Set-AtpPolicyForO365 -AllowClickThrough $False -EnableSafeLinksForClients
$true
```

ARCHIVE

Impact:

User impact associated with this change is minor - users may experience a very short delay when clicking on URLs in Office documents before being directed to the requested site.

CIS Controls:

Version 7

7.4 Maintain and Enforce Network-Based URL Filters

Enforce network-based URL filters that limit a system's ability to connect to websites not approved by the organization. This filtering shall be enforced for each of the organization's systems, whether they are physically at an organization's facilities or not.

ARCHIVE

2.4 (L2) Ensure Office 365 ATP for SharePoint, OneDrive, and Microsoft Teams is Enabled (Automated)

Profile Applicability:

- E5 Level 2

Description:

Office 365 ATP for SharePoint, OneDrive, and Microsoft Teams scans these services for malicious files.

Rationale:

Office 365 ATP for SharePoint, OneDrive, and Microsoft Teams protects your organization from inadvertently sharing malicious files. When a malicious file is detected, that file is blocked so that no one can open, copy, move, or share it until further actions are taken by the organization's security team.

Audit:

To verify that O365 ATP is enabled for SharePoint, OneDrive, and Microsoft Teams, use the Microsoft 365 Admin Center:

1. Under `Admin centers` click `Security` to open the `Microsoft 365 Security Center`.
2. Navigate to `Policies` and select `ATP safe attachments`.
3. Verify that `Turn on ATP` for `SharePoint`, `OneDrive`, and `Microsoft Teams` is `checked`.

To verify that O365 ATP is enabled for SharePoint, OneDrive, and Microsoft Teams, use the Exchange Online PowerShell Module:

1. Connect using `Connect-EXOPSSession`.
2. Run the following PowerShell command:

```
Get-AtpPolicyForO365 | fl Name,EnableATPForSPOTeamsODB
```

3. Verify the value for `EnableATPForSPOTeamsODB` is set to `True`.

ARCHIVE

Remediation:

To enable O365 ATP for SharePoint, OneDrive, and Microsoft Teams, use the Microsoft 365 Admin Center:

1. Under `Admin centers` click `Security` to open the `Microsoft 365 Security Center`.
2. Navigate to `Policies` and select `ATP safe attachments`.
3. Ensure that `Turn on ATP` for `SharePoint`, `OneDrive`, and `Microsoft Teams` is `checked`.

To enable O365 ATP for SharePoint, OneDrive, and Microsoft Teams, use the Exchange Online PowerShell Module:

1. Connect using `Connect-EXOPSSession`.
2. Run the following PowerShell command:

```
Set-AtpPolicyForO365 -EnableATPForSPOTeamsODB $True
```

Impact:

Impact associated with O365 ATP is minimal, and equivalent to impact associated with anti-virus scanners in an environment.

CIS Controls:

Version 7

7.10 Sandbox All Email Attachments
Use sandboxing to analyze and block inbound email attachments with malicious behavior.

8.1 Utilize Centrally Managed Anti-malware Software
Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.

ARCHIVE

2.5 (L2) Ensure Office 365 SharePoint infected files are disallowed for download (Automated)

Profile Applicability:

- E5 Level 2

Description:

By default SharePoint online allows files that ATP has detected as infected to be downloaded.

Rationale:

Office 365 ATP for SharePoint, OneDrive, and Microsoft Teams protects your organization from inadvertently sharing malicious files. When an infected file is detected, that file is blocked so that no one can open, copy, move, or share it until further actions are taken by the organization's security team.

Audit:

To check that O365 SharePoint is set to not allow infected files to be downloaded, use Powershell:

1. Connect using `Connect-SPOService`, you will need to enter the URL for your Sharepoint Online admin page `https://*-admin.sharepoint.com` as well as a Global Admin account.
2. Run the following Powershell command

```
Get-SPOTenant | Select-Object DisallowInfectedFileDownload
```

3. Verify the value for `DisallowInfectedFileDownload` is set to `True`.

ARCHIVE

Remediation:

To set O365 SharePoint to disallow download of infected files, use Powershell:

1. Connect using `Connect-SPOService`, you will need to enter the URL for your Sharepoint Online admin page `https://*-admin.sharepoint.com` as well as a Global Admin account.
2. Run the following Powershell command to set the value to `True`.

```
Set-SPOTenant -DisallowInfectedFileDownload $true
```

3. After several minutes run the following to verify the value for `DisallowInfectedFileDownload` has been set to `True`.

```
Get-SPOTenant | Select-Object DisallowInfectedFileDownload
```

Impact:

The only potential impact associated with implementation of this setting is potential inconvenience associated with the small percentage of false positive detections that may occur.

References:

1. https://docs.microsoft.com/en-us/microsoft-365/security/office-365-security/turn-on-atp-for-spo-odb-and-teams
2. https://docs.microsoft.com/en-us/microsoft-365/security/office-365-security/virus-detection-in-spo?view=o365-worldwide

CIS Controls:

Version 7

7.10 Sandbox All Email Attachments
Use sandboxing to analyze and block inbound email attachments with malicious behavior.

8.1 Utilize Centrally Managed Anti-malware Software
Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.

ARCHIVE

2.6 (L2) Ensure user consent to apps accessing company data on their behalf is not allowed (Automated)

Profile Applicability:

- E3 Level 2

Description:

By default, users can consent to applications accessing your organization's data, although only for some permissions. For example, by default a user can consent to allow an app to access their own mailbox or the Teams conversations for a team the user owns, but cannot consent to allow an app unattended access to read and write to all SharePoint sites in your organization.

Do not allow users to grant consent to apps accessing company data on their behalf.

Rationale:

Attackers commonly use custom applications to trick users into granting them access to company data.

While allowing users to consent by themselves does allow users to easily acquire useful applications that integrate with Microsoft 365, Azure and other services, it can represent a risk if not used and monitored carefully.

Disable future user consent operations to help reduce your threat-surface and mitigate this risk. If user consent is disabled, previous consent grants will still be honored but all future consent operations must be performed by an administrator.

ARCHIVE

Audit:

To verify that user consent to apps accessing company data on their behalf is not allowed, use the Microsoft 365 Admin Center:

1. Select `Admin Centers` and `Azure Active Directory`.
2. Select `Enterprise Applications` from the Azure navigation pane.
3. Select `Users Settings`.
4. Verify `Users can consent to apps accessing company data on their behalf` is set to `No`.

To verify that user consent to apps accessing company data on their behalf is not allowed, use the Microsoft Online PowerShell Module:

1. Connect to Microsoft Online service using `Connect-MSOLService`.
2. Run the following Microsoft Online PowerShell command:

```
Get-MsolCompanyInformation | Select-Object
UsersPermissionToUserConsentToAppEnabled
```

3. Verify the value for `UsersPermissionToUserConsentToAppEnabled` is set to `False`.

Remediation:

To prohibit user consent to apps accessing company data on their behalf, use the Microsoft 365 Admin Center:

1. Select `Admin Centers` and `Azure Active Directory`.
2. Select `Enterprise Applications` from the Azure navigation pane.
3. Select `Users Settings`.
4. Set `Users can consent to apps accessing company data on their behalf` to `No`.
5. Click the `Save` option at the top of the window.

To prohibit user consent to apps accessing company data on their behalf, use the Microsoft Online PowerShell Module:

1. Connect to Microsoft Online service using `Connect-MSOLService`.
2. Run the following Microsoft Online PowerShell command:

```
Set-MsolCompanySettings -UsersPermissionToUserConsentToAppEnabled $False
```

ARCHIVE

Impact:

If user consent is disabled, previous consent grants will still be honored but all future consent operations must be performed by an administrator. Tenant-wide admin consent can be requested by users through an integrated administrator consent request workflow or through organizational support processes.

Default Value:

UI - `Yes` PowerShell - `True`

CIS Controls:

Version 7

14.6 Protect Information through Access Control Lists

Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.

ARCHIVE

2.7 (L2) Ensure the admin consent workflow is enabled (Automated)

Profile Applicability:

- E3 Level 2

Description:

Without an admin consent workflow (Preview), a user in a tenant where user consent is disabled will be blocked when they try to access any app that requires permissions to access organizational data. The user sees a generic error message that says they're unauthorized to access the app and they should ask their admin for help.

Rationale:

The admin consent workflow (Preview) gives admins a secure way to grant access to applications that require admin approval. When a user tries to access an application but is unable to provide consent, they can send a request for admin approval. The request is sent via email to admins who have been designated as reviewers. A reviewer takes action on the request, and the user is notified of the action.

Audit:

To verify the admin consent workflow (Preview) is enabled, use the Microsoft 365 Admin Center:

1. Select `Admin Centers` and `Azure Active Directory`.
2. Select `Enterprise Applications` from the Azure Navigation pane.
3. Select `Users Settings`.
4. Verify that `Admin consent requests (Preview)` is set to `Yes`.

ARCHIVE

Remediation:

To enable the admin consent workflow (Preview), use the Microsoft 365 Admin Center:

1. Select `Admin Centers` and `Azure Active Directory`.
2. Select `Enterprise Applications` from the Azure Navigation pane.
3. Select `Users Settings`.
4. Set `Admin consent requests (Preview)` to `Yes`.
5. Select `Select admin consent request reviewers` and choose the admins you would like to review user generated app consent requests.
6. Select `Save` at the top of the window.

Impact:

To approve requests, a reviewer must be a global administrator, cloud application administrator, or application administrator. The reviewer must already have one of these admin roles assigned; simply designating them as a reviewer doesn't elevate their privileges.

Default Value:

- `Users can request admin consent to apps they are unable to consent to: No`
- `Selected users to review admin consent requests: None`
- `Selected users will receive email notifications for requests: Yes`
- `Selected users will receive request expiration reminders: Yes`
- `Consent request expires after (days): 30`

CIS Controls:

Version 7

18.3 <u>Verify That Acquired Software is Still Supported</u>

Verify that the version of all software acquired from outside your organization is still supported by the developer or appropriately hardened based on developer security recommendations.

ARCHIVE

2.8 (L2) - Ensure users installing Outlook add-ins is not allowed (Automated)

Profile Applicability:

- E3 Level 2

Description:

By default, users can install add-ins in their Microsoft Outlook Desktop client, allowing data access within the client application.

Do not allow users to install add-ins in Outlook.

Rationale:

Attackers commonly use vulnerable and custom-built add-ins to access data in user applications.

While allowing users to install add-ins by themselves does allow them to easily acquire useful add-ins that integrate with Microsoft applications, it can represent a risk if not used and monitored carefully.

Disable future user's ability to install add-ins in Microsoft Outlook helps reduce your threat-surface and mitigate this risk.

ARCHIVE

Audit:

To verify that users installing Outlook add-ins is not allowed, use the Microsoft 365 Admin Center:

1. Select `Admin Centers` and `Exchange`.
2. Select `Permissions` from the Exchange navigation pane.
3. Select `User Roles`.
4. Verify `My Custom Apps` `My Marketplace Apps` and `My ReadWriteMailboxApps` are `Not Checked`.

To verify that users installing Outlook add-ins is not allowed, use the Microsoft Online PowerShell Module:

1. Connect to Microsoft Online service using `Connect-EXOPSSession`.
2. Run the following Microsoft Online PowerShell command:

```
Get-Mailbox | Select-Object -Unique RoleAssignmentPolicy | ForEach-Object {
Get-RoleAssignmentPolicy -Identity $_.RoleAssignmentPolicy | Where-Object
{$_.AssignedRoles -like "*Apps*"}} | Select-Object Identity,
@{Name="AssignedRoles"; Expression={Get-Mailbox | Select-Object -Unique
RoleAssignmentPolicy | ForEach-Object { Get-RoleAssignmentPolicy -Identity
$_.RoleAssignmentPolicy | Select-Object -ExpandProperty AssignedRoles |
Where-Object {$_ -like "*Apps*"}}}}
```

3. Verify `My Custom Apps` `My Marketplace Apps` and `My ReadWriteMailboxApps` are not present.

ARCHIVE

Remediation:

To prohibit users installing Outlook add-ins, use the Microsoft 365 Admin Center:

1. Select `Admin Centers` and `Exchange`.
2. Select `Permissions` from the Exchange navigation pane.
3. Select `User Roles`.
4. De-Select `My Custom Apps` `My Marketplace Apps` and `My ReadWriteMailboxApps`.

To prohibit users installing Outlook add-ins, use the Microsoft Online PowerShell Module:

1. Connect to Microsoft Online service using `Connect-MSOLService`.
2. Run the following Microsoft Online PowerShell command:

```
$newPolicyName = "Role Assignment Policy - Prevent Add-ins"
$revisedRoles = "MyTeamMailboxes", "MyTextMessaging", "MyDistributionGroups",
"MyMailSubscriptions", "MyBaseOptions", "MyVoiceMail",
"MyProfileInformation", "MyContactInformation", "MyRetentionPolicies",
"MyDistributionGroupMembership"

New-RoleAssignmentPolicy -Name $newPolicyName -Roles $revisedRoles
Set-RoleAssignmentPolicy -id $newPolicyName -IsDefault
Get-Mailbox -ResultSize Unlimited | Set-Mailbox -RoleAssignmentPolicy
$newPolicyName
```

If you have other Role Assignment Policies modify the last line to filter out your custom policies

Impact:

Implementation of this change will impact both end users and administrators. End users will not be able to integrate third-party applications that they may wish to use. Administrators are likely to receive requests from end users to grant them permission to necessary third-party applications.

ARCHIVE

Default Value:

UI - `My Custom Apps` is `Checked`, `My Marketplace Apps` is `Checked`, and `My ReadWriteMailboxApps` is `Checked`

PowerShell - `My Custom Apps` `My Marketplace Apps` and `My ReadWriteMailboxApps` are `Present`

CIS Controls:

Version 7

5.1 Establish Secure Configurations

Maintain documented, standard security configuration standards for all authorized operating systems and software.

ARCHIVE

2.9 (L1) - Ensure users installing Word, Excel, and PowerPoint add-ins is not allowed (Manual)

Profile Applicability:

- E3 Level 1

Description:

By default, users can install add-ins in their Microsoft Word, Excel, and PowerPoint applications, allowing data access within the application.

Do not allow users to install add-ins in Word, Excel, or PowerPoint.

Rationale:

Attackers commonly use vulnerable and custom-built add-ins to access data in user applications.

While allowing users to install add-ins by themselves does allow them to easily acquire useful add-ins that integrate with Microsoft applications, it can represent a risk if not used and monitored carefully.

Disable future user's ability to install add-ins in Microsoft Word, Excel, or PowerPoint helps reduce your threat-surface and mitigate this risk.

Audit:

To verify that users installing Word, Excel, and PowerPoint add-ins is not allowed, use the Microsoft 365 Admin Center:

1. Select `Settings` from the navigation pane.
2. Select `Org Settings` from the navigation pane.
3. Under `Services` select `User Owned apps and services`.
4. Verify `Let users access the Office Store` and `Let users install trial apps and services` are `Not Checked`.

ARCHIVE

Remediation:

To prohibit users installing Word, Excel, and PowerPoint add-ins, use the Microsoft 365 Admin Center:

1. Select `Settings` from the navigation pane.
2. Select `Org Settings` from the navigation pane.
3. Under `Services` select `User Owned apps and services`.
4. De-Select `Let users access the Office Store` and `Let users install trial apps and services`.

Impact:

Implementation of this change will impact both end users and administrators. End users will not be able to install add-ins that they may want to install.

Default Value:

`Let users access the Office Store` is `Checked`

`Let users install trial apps and services` is `Checked`

CIS Controls:

Version 7

5.1 Establish Secure Configurations

Maintain documented, standard security configuration standards for all authorized operating systems and software.

ARCHIVE

3 Data Management

3.1 (L2) Ensure the customer lockbox feature is enabled (Automated)

Profile Applicability:

- E5 Level 2

Description:

You should enable the Customer Lockbox feature. It requires Microsoft to get your approval for any datacenter operation that grants a Microsoft support engineer or other employee direct access to any of your data. For example, in some cases a Microsoft support engineer might need access to your Microsoft 365 content in order to help troubleshoot and fix an issue for you. Customer lockbox requests also have an expiration time, and content access is removed after the support engineer has fixed the issue.

Rationale:

Enabling this feature protects your data against data spillage and exfiltration.

Audit:

To verify the Customer Lockbox feature is enabled, use the Microsoft 365 Admin Portal:

1. Browse to the `Microsoft 365 admin center`.
2. Expand `Settings` then select `Settings`
3. Choose `Security & privacy` in the right pane.
4. Click `Customer Lockbox`.
5. Ensure the box labeled `Require approval for all data access requests` is checked.

ARCHIVE

To verify the Customer Lockbox feature is enabled, use the Microsoft 365 SecureScore Portal:

1. Log in to the Microsoft 365 SecureScore portal (https://securescore.microsoft.com) using admin permissions (global admin or a custom admin role) for an Office 365 Enterprise, Microsoft 365 Business, or Office 365 Business Premium subscription.
2. Search for `Turn on customer lockbox feature` under `Improvement actions`

To verify the Customer Lockbox feature is enabled, use the REST API:

```
GET https://graph.microsoft.com/beta/security/secureScores
```

To verify the Customer Lockbox feature is enabled, use the Microsoft Online PowerShell Module:

1. Run Exchange Online PowerShell Module.
2. Connect using `Connect-EXOPSSession`.
3. Run the following PowerShell command:

```
Get-OrganizationConfig |Select-Object CustomerLockBoxEnabled
```

4. Verify the value is set to `True`

Remediation:

To enable the Customer Lockbox feature, use the Microsoft 365 Admin Portal:

1. Browse to the `Microsoft 365 admin center`.
2. Expand `Settings` then select `Settings`
3. Choose `Security & privacy` in the right pane.
4. Click `Customer Lockbox`.
5. Check the the box `Require approval for all data access requests`.
6. Click `Save changes`.

ARCHIVE

Impact:

The impact associated with this setting is a requirement to grant Microsoft access to the tenant environment prior to a Microsoft engineer accessing the environment for support or troubleshooting.

Default Value:

Disabled

CIS Controls:

Version 7

13 Data Protection
Data Protection

13.3 Monitor and Block Unauthorized Network Traffic
Deploy an automated tool on network perimeters that monitors for unauthorized transfer of sensitive information and blocks such transfers while alerting information security professionals.

ARCHIVE

3.2 (L2) Ensure SharePoint Online data classification policies are set up and used (Manual)

Profile Applicability:

- E3 Level 2

Description:

You should set up and use SharePoint Online data classification policies on data stored in your SharePoint Online sites.

Rationale:

The policies will help categorize your most important data so you can effectively protect it from illicit access, and will help make it easier to investigate discovered breaches.

Audit:

To verify data classification policies are set up, use the Microsoft 365 Admin Center:

1. Under `Admin centers` select `Compliance` to open the `Microsoft 365 Compliance Center`.
2. Expand `Classification` then choose `Sensitivity labels`.
3. Ensure Labels exist.

Remediation:

To set up data classification policies, use the Microsoft 365 Admin Center:

1. Under `Admin centers` select `Compliance` to open the `Microsoft 365 Compliance Center`.
2. Expand `Classification` then choose `Sensitivity labels`.
3. Click `Create label` to create a label.

ARCHIVE

Impact:

Creation of data classification policies will not cause a significant impact to an organization. However, ensuring long term adherence with policies can potentially be a significant training and ongoing compliance effort across an organization. Organizations should ensure that training and compliance planning is part of the classification policy creation process.

CIS Controls:

Version 7

13.1 Maintain an Inventory Sensitive Information

Maintain an inventory of all sensitive information stored, processed, or transmitted by the organization's technology systems, including those located onsite or at a remote service provider.

14.6 Protect Information through Access Control Lists

Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.

ARCHIVE

3.3 (L2) Ensure external domains are not allowed in Skype or Teams (Manual)

Profile Applicability:

- E3 Level 2

Description:

Disable the ability of your users to communicate via Skype or Teams with users outside your organization.

Rationale:

You should not allow your users to communicate with Skype or Teams users outside your organization. While there are legitimate, productivity-improving scenarios for this, it also represents a potential security threat because those external users will be able to interact with your users over Skype for Business or Teams. Attackers may be able to pretend to be someone your user knows and then send malicious links or attachments, resulting in an account breach or leaked information.

Audit:

To verify Skype for Business and Teams access with external users is disabled, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` choose `Teams`.
2. Expand `Org Wide Settings` then select `External Access`.
3. Verify that `Users can communicate with Skype for Business and Teams users` is set to `Off`.
4. Verify that `Skype for Business users can communicate with Skype users` is set to `Off`.

ARCHIVE

Remediation:

To disable Skype for Business and Teams access with external users, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` choose `Teams`.
2. Expand `Org Wide Settings` then select `External Access`.
3. Set `Users can communicate with Skype for Business and Teams users` to `Off`.
4. Set `Skype for Business users can communicate with Skype users` to `Off`.

Impact:

Impact associated with this change is highly dependent upon current practices in the tenant. If users do not regularly communicate with external parties using Skype or Teams channels, then minimal impact is likely. However, if users do regularly utilize Teams and Skype for client communication, potentially significant impacts could occur, and users should be contacts, and if necessary, alternate mechanisms to continue this communication should be identified prior to disabling external access to Teams and Skype.

Default Value:

On

CIS Controls:

Version 7

14.6 Protect Information through Access Control Lists

Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.

ARCHIVE

3.4 (L1) Ensure DLP policies are enabled (Automated)

Profile Applicability:

- E3 Level 1

Description:

Enabling Data Loss Prevention (DLP) policies allows Exchange Online and SharePoint Online content to be scanned for specific types of data like social security numbers, credit card numbers, or passwords.

Rationale:

Enabling DLP policies alerts users and administrators that specific types of data should not be exposed, helping to protect the data from accidental exposure.

Audit:

To verify DLP policies are enabled, use the Microsoft 365 Admin Center:

1. Under `Admin centers` Select `Compliance`.
2. From the `Microsoft 365 compliance center` select `Improvement actions` then `Apply Data Loss Prevention` then choose `Policy`.
3. Verify that policies exist and are enabled

To verify the DLP feature is enabled, use the Microsoft 365 SecureScore Portal:

1. Login to Microsoft 365 SecureScore portal (https://securescore.microsoft.com) using admin permissions (global admin or a custom admin role) for an Office 365 Enterprise, Microsoft 365 Business, or Office 365 Business Premium subscription.
2. Click on `Apply Data Loss Prevention policies` policy to check if policies are being applied.
3. Check the number of data loss prevention policy applied

To verify the DLP feature is enabled, use the REST API:

```
GET https://graph.microsoft.com/beta/security/secureScores
```

ARCHIVE

Remediation:

To enable DLP policies, use the Microsoft 365 Admin Center:

1. Under `Admin centers` Select `Compliance`.
2. From the `Microsoft 365 compliance center` expand `Data loss prevention` then choose `Policy`.
3. Click `Create a policy`.

Impact:

Enabling a Teams DLP policy will allow sensitive data in Exchange Online and SharePoint Online to be detected or blocked.

CIS Controls:

Version 7

13 Data Protection
Data Protection

14.7 Enforce Access Control to Data through Automated Tools
Use an automated tool, such as host-based Data Loss Prevention, to enforce access controls to data even when data is copied off a system.

ARCHIVE

3.5 (L1) Ensure DLP policies are enabled for Microsoft Teams (Manual)

Profile Applicability:

- E5 Level 1

Description:

Enabling Data Loss Prevention (DLP) policies for Microsoft Teams, blocks sensitive content when shared in teams or channels. Content to be scanned for specific types of data like social security numbers, credit card numbers, or passwords.

Rationale:

Enabling DLP policies alerts users and administrators that specific types of data should not be exposed, helping to protect the data from accidental exposure.

Audit:

To verify DLP policies are enabled, use the Microsoft 365 Admin Center:

1. Select `Compliance` under `Admin centers`.
2. From the `Microsoft 365 compliance center` choose `Policies` select `Data loss prevention`
3. Select `Data loss prevention`.
4. Click `Policy`.
5. Verify that policies exist and are enabled
6. Ensure that the policies include the location `Teams chat and channel messages`

To verify the DLP feature is enabled, use the Microsoft 365 SecureScore Portal:

1. Login to Microsoft 365 SecureScore portal (https://securescore.microsoft.com) using admin permissions (global admin or a custom admin role) for an Office 365 Enterprise, Microsoft 365 Business, or Office 365 Business Premium subscription.
2. Click on `Apply Data Loss Prevention policies` policy to check if policies are being applied.
3. Check the number of data loss prevention policy applied

To verify the DLP feature is enabled, use the REST API:

```
GET https://graph.microsoft.com/beta/security/secureScores
```

ARCHIVE

Remediation:

To enable DLP policies, use the Microsoft 365 Admin Center:

1. Select `Compliance` under `Admin centers`.
2. From the `Microsoft 365 compliance center` choose `Policies` select `Data loss prevention`
3. Select `Data loss prevention`.
4. Click `Policy`.
5. Click `Create a policy`.
6. Either start with a template or create a custom policy.
7. Provide a `Name` for your policy
8. At the `Choose locations` step, either choose `Protect content in Exchange email, Teams chats and channel messages and OneDrive and SharePoint documents` or select `Let me choose specific locations`. If you select `Let me choose specific locations`, ensure that `Teams chat and channel messages` is selected.
9. Ensure that the proper DLP rules are created for the type of content to be detected and what actions should be taken.

Impact:

Enabling a Teams DLP policy will allow sensitive data in Teams channels or chat messages to be detected or blocked.

Default Value:

This is not enabled by default.

CIS Controls:

Version 7

13 Data Protection
Data Protection

14.7 Enforce Access Control to Data through Automated Tools
Use an automated tool, such as host-based Data Loss Prevention, to enforce access controls to data even when data is copied off a system.

ARCHIVE

3.6 (L2) Ensure that external users cannot share files, folders, and sites they do not own (Automated)

Profile Applicability:

- E3 Level 2

Description:

SharePoint gives users the ability to share files, folder, and site collections. Internal users can share with external collaborators, who with the right permissions, could share those to another external party.

Rationale:

Sharing and collaboration are key; however, file, folder, or site collection owners should have the authority over what external users get shared with to prevent unauthorized disclosures of information.

Audit:

To verify SharePoint sharing settings, use the Microsoft 365 Admin Center:

1. Under `Admin centers` select `SharePoint`.
2. Expand `Policies` then select `Sharing`.
3. Expand `More external sharing settings`, verify that `Allow guests to share items they don't own` is unchecked.

To verify Prevent external users from sharing files, folders, and sites that they don't own, use the SharePoint Online PowerShell Module:

1. Connect to SharePoint Online service using `Connect-SPOService`.
2. Run the following SharePoint Online PowerShell command:

```
Get-SPOTenant | ft PreventExternalUsersFromResharing
```

3. Verify `PreventExternalUsersFromResharing` is set True

ARCHIVE

Remediation:

To set SharePoint sharing settings, use the Microsoft 365 Admin Center:

1. Under `Admin centers` select `SharePoint`.
2. Expand `Policies` then select `Sharing`.
3. Expand `More external sharing settings`, uncheck `Allow guests to share items they don't own`.
4. Click `Save`.

To Set Prevent external users from sharing files, folders, and sites that they don't own, use the SharePoint Online PowerShell Module:

1. Connect to SharePoint Online service using `Connect-MSOLService`.
2. Run the following SharePoint Online PowerShell command:

```
Set-SPOTenant -PreventExternalUsersFromResharing $True
```

Impact:

Impact associated with this change is highly dependent upon current practices. If users do not regularly share with external parties, then minimal impact is likely. However, if users do regularly share with guests/externally, minimum impacts could occur as those external users will be unable to 're-share' content.

CIS Controls:

Version 7

14.6 <u>Protect Information through Access Control Lists</u>

Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.

ARCHIVE

3.7 (L2) Ensure external file sharing in Teams is enabled for only approved cloud storage services (Manual)

Profile Applicability:

- E3 Level 2

Description:

Microsoft Teams enables collaboration via file sharing. This file sharing is conducted within Teams, using SharePoint Online, by default; however, third-party cloud services are allowed as well.

Rationale:

Ensuring that only authorized cloud storage providers are accessible from Teams will help to dissuade the use of non-approved storage providers.

Audit:

To verify external file sharing in Teams, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` choose `Teams`.
2. Expand `Org-wide settings` select `Teams settings`.
3. Verify `Files` is set to `On` for only authorized cloud storage options.

ARCHIVE

** To verify external file sharing in Teams you may also utilize Powershell. Ensure that the Skype for business online, Windows Powershell module and Microsoft Teams module are both installed. **

1. Install the Powershell module for teams. Skype module will need downloaded from Microsoft.

```
Install-Module MicrosoftTeams
Import-Module SkypeOnlineConnector
```

2. Connect to your tenant as a Global Administrator, methods will differ based on whether 2FA is enabled. See the following article for more information - https://docs.microsoft.com/en-us/office365/enterprise/powershell/manage-skype-for-business-online-with-office-365-powershell
3. Run the following command to verify which cloud storage providers are enabled for Teams

```
Get-CsTeamsClientConfiguration | select allow*
```

4. Verify that only allowed authorized providers are set to 'True'.

Remediation:

To Set external file sharing in Teams, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` choose `Teams`.
2. Expand `Org-wide settings` select `Teams settings`.
3. Set each cloud storage service under `Files` to `On` if it is authorized.

ARCHIVE

** To verify external file sharing in Teams you may also utilize Powershell. Ensure that the Skype for business online, Windows Powershell module and Microsoft Teams module are both installed. **

1. Install the Powershell module for teams. Skype module will need downloaded from Microsoft.

```
Install-Module MicrosoftTeams
Import-Module SkypeOnlineConnector
```

2. Connect to your tenant as a Global Administrator, methods will differ based on whether 2FA is enabled. See the following article for more information - https://docs.microsoft.com/en-us/office365/enterprise/powershell/manage-skype-for-business-online-with-office-365-powershell
3. Run the following command to verify which cloud storage providers are enabled for Teams

```
Get-CsTeamsClientConfiguration | select allow*
```

4. Run the following Powershell command to disable external providers that are not authorized. (the example disables ShareFile, GoogleDrive, Box, and DropBox

```
Set-CsTeamsClientConfiguration -AllowGoogleDrive $false -AllowShareFile
$false -AllowBox $false -AllowDropBox $false
```

5. You may verify this worked by running the following Powershell command again.

```
Get-CsTeamsClientConfiguration | select allow*
```

Impact:

Impact associated with this change is highly dependent upon current practices in the tenant. If users do not use other storage providers, then minimal impact is likely. However, if users do regularly utilize providers outside of the tenant this will affect their ability to continue to do so.

ARCHIVE

Default Value:

On

Notes:

Skype Online Connector - https://www.microsoft.com/en-us/download/details.aspx?id=39366

CIS Controls:

Version 7

14.7 Enforce Access Control to Data through Automated Tools

Use an automated tool, such as host-based Data Loss Prevention, to enforce access controls to data even when data is copied off a system.

ARCHIVE

4 Email Security / Exchange Online

4.1 (L1) Ensure the Common Attachment Types Filter is enabled (Automated)

Profile Applicability:

- E3 Level 1

Description:

The Common Attachment Types Filter lets a user block known and custom malicious file types from being attached to emails.

Rationale:

Blocking known malicious file types can help prevent malware-infested files from infecting a host.

Audit:

To verify the Common Attachment Types Filter is enabled, use the Microsoft 365 Admin Portal:

1. Navigate to the Exchange Admin Center and click `Protection` > `Malware Filter`.
2. Edit the `Default` profile.
3. In the Edit tab under `Settings`, verify that the `Common Attachment Types Filter` has the value of 'On - Emails with attachments of filtered file types will trigger the Malware Detection Response (recommended).`

To verify the Common Attachment Types Filter is enabled, use the Exchange Online PowerShell Module:

1. Connect to Exchange Online using `Connect-EXOPSSession`.
2. Run the following Exchange Online PowerShell command:

```
Get-MalwareFilterPolicy -Identity Default | Select-Object EnableFileFilter
```

3. Verify `EnableFileFilter` is set to `True`.

ARCHIVE

Remediation:

To enable the Common Attachment Types Filter, use the Microsoft 365 Admin Portal:

1. Navigate to the Exchange Admin Center and click `Protection` > `Malware Filter`.
2. Edit the `Default` profile.
3. Click on the Edit tab under `Settings`. Ensure that the `Common Attachment Types Filter` has the value of `On - Emails with attachments of filtered file types will trigger the Malware Detection Response (recommended)`.

To enable the Common Attachment Types Filter, use the Exchange Online PowerShell Module:

1. Connect to Exchange Online using `Connect-EXOPSSession`.
2. Run the following Exchange Online PowerShell command:

```
Set-MalwareFilterPolicy -Identity Default -EnableFileFilter $true
```

Impact:

Blocking common malicious file types should not cause an impact in modern computing environments.

Default Value:

off

References:

1. https://docs.microsoft.com/en-us/powershell/module/exchange/antispam-antimalware/Get-MalwareFilterPolicy?view=exchange-ps
2. https://docs.microsoft.com/en-us/office365/SecurityCompliance/configure-anti-malware-policies#use-remote-powershell-to-configure-anti-malware-policies

CIS Controls:

Version 7

7.9 Block Unnecessary File Types

Block all e-mail attachments entering the organization's e-mail gateway if the file types are unnecessary for the organization's business.

8.1 Utilize Centrally Managed Anti-malware Software

Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.

ARCHIVE

4.2 (L1) Ensure Exchange Online Spam Policies are set correctly (Automated)

Profile Applicability:

- E3 Level 1

Description:

You should set your Exchange Online Spam Policies to copy emails and notify someone when a sender in your tenant has been blocked for sending spam emails.

Rationale:

A blocked account is a good indication that the account in question has been breached and an attacker is using it to send spam emails to other people.

Audit:

To verify the Exchange Online Spam Policies are set correctly, use the Microsoft 365 Admin Center:

1. Go to https://protection.office.com/antispam
2. Expand `Outbound spam filter policy (always ON)`.
3. Verify that `Send copies of suspicious messages to specific people` is set to `On`, ensure the email address is correct.
4. Verify that `Notify specific people if senders are blocked` is set to `On`, ensure the email address is correct.

To verify the Exchange Online Spam Policies are set correctly, use the Exchange Online PowerShell Module:

1. Connect to Exchange Online using `Connect-EXOPSSession`.
2. Run the following PowerShell command:

```
Get-HostedOutboundSpamFilterPolicy | Select-Object Bcc*, Notify*
```

3. Verify both `BccSuspiciousOutboundMail` and `NotifyOutboundSpam` are set to `True` and the email addresses to be notified are correct.

ARCHIVE

Remediation:

To set the Exchange Online Spam Policies correctly, use the Microsoft 365 Admin Center:

1. Go to https://protection.office.com/antispam
2. Expand `Outbound spam filter policy (always ON)`.
3. Select `Edit policy` then expand `Notifications`
4. Check `Send copies of suspicious messages to specific people` then select `+Add people`, enter the desidred email addresses.
5. Check `Notify specific people if senders are blocked` then select `+Add people`, enter the desidred email addresses.
6. Click `Save`.

To set the Exchange Online Spam Policies correctly, use the Exchange Online PowerShell Module:

1. Connect to Exchange Online using `Connect-EXOPSSession`.
2. Run the following PowerShell command:

```
$BccEmailAddress = @("<INSERT-EMAIL>")

$NotifyEmailAddress = @("<INSERT-EMAIL>")

Set-HostedOutboundSpamFilterPolicy -Identity Default -
BccSuspiciousOutboundAdditionalRecipients $BccEmailAddress -
BccSuspiciousOutboundMail $true -NotifyOutboundSpam $true -
NotifyOutboundSpamRecipients $NotifyEmailAddress
```

ARCHIVE

Impact:

Notification of users that have been blocked should not cause an impact to the user.

Default Value:

disabled

CIS Controls:

Version 7

7.10 Sandbox All Email Attachments
Use sandboxing to analyze and block inbound email attachments with malicious behavior.

7.9 Block Unnecessary File Types
Block all e-mail attachments entering the organization's e-mail gateway if the file types are unnecessary for the organization's business.

ARCHIVE

4.3 (L1) Ensure mail transport rules do not forward email to external domains (Automated)

Profile Applicability:

- E3 Level 1

Description:

You should set your Exchange Online mail transport rules to not forward email to domains outside of your organization.

Rationale:

Attackers often create these rules to exfiltrate data from your tenancy.

Audit:

To verify the mail transport rules do not forward email to external domains, use the Microsoft 365 Admin Center:

1. Select `Exchange`.
2. Select `Mail Flow` and `Rules`.
3. Review the rules and verify that none of them are forwards to external domains.

To verify that no rules are are forwarding email to external domains, you can also use the Exchange Online PowerShell module:

1. Connect to Exchange online using Connect-EXOPSSession
2. Run the following PowerShell command to review the Transport Rules that are redirecting email:

```
Get-TransportRule | Where-Object {$_.RedirectMessageTo -ne $null} | ft
Name,RedirectMessageTo
```

3. Verify that none of the addresses are going to external domains

ARCHIVE

Remediation:

To alter the mail transport rules so they do not forward email to external domains, use the Microsoft 365 Admin Center:

1. Select `Exchange`.
2. Select `Mail Flow` and `Rules`.
3. For each rule that forwards email to external domains, select the rule and click the 'Delete' icon.

To perform remediation you may also use the Exchange Online PowerShell Module:

1. Connect to Exchange Online user Connect-EXOPSSession
2. Run the following Powershell command:

```
Remove-TransportRule {RuleName}
```

3. To verify this worked you may re-run the audit command as follows:

```
Get-TransportRule | Where-Object {$_.RedirectMessageTo -ne $null} | ft
Name,RedirectMessageTo
```

Impact:

Care should be taken before implementation to ensure there is no business need for case-by-case auto-forwarding. Disabling auto-forwarding to remote domains will affect all users and in an organization.

References:

1. https://docs.microsoft.com/en-us/exchange/policy-and-compliance/mail-flow-rules/mail-flow-rule-procedures?view=exchserver-2019

CIS Controls:

Version 7

7 Email and Web Browser Protections
Email and Web Browser Protections

ARCHIVE

4.4 (L2) Ensure automatic forwarding options are disabled (Automated)

Profile Applicability:

- E3 Level 2

Description:

You should disable automatic forwarding to prevent users from auto-forwarding mail through Outlook and Outlook on the Web.

Rationale:

In the event that an attacker gains control of an end-user account they could create rules to ex-filtrate data from your environment.

Audit:

To verify that auto forwarding is disabled, you may use the Exchange Online PowerShell:

1. Connect to Exchange online using Connect-EXOPSSession
2. Run the following Powershell to find if auto-forwarding is enabled to remote domains:

```
Get-RemoteDomain Default | fl AllowedOOFType, AutoForwardEnabled
```

3. Review the `AutoForwardEnabled` parameter, and verify it is set to `False`.

Remediation:

To perform remediation you may use the Exchange Online PowerShell Module:

1. Connect to Exchange online using Connect-EXOPSSession
2. Run the following Powershell to disable auto-forwarding to remote domains:

```
Set-RemoteDomain Default -AutoForwardEnabled $false
```

3. Run the following Powershell to verify `AutoForwardEnabled` is now set to `False`.

```
Get-RemoteDomain Default | fl AllowedOOFType, AutoForwardEnabled
```

ARCHIVE

Impact:

Care should be taken before implementation to ensure there is no business need for case-by-case auto-forwarding. Disabling auto-forwarding to remote domains will affect all users and in an organization.

Default Value:

True

References:

1. https://docs.microsoft.com/en-us/archive/blogs/exovoice/disable-automatic-forwarding-in-office-365-and-exchange-server-to-prevent-information-leakage
2. https://docs.microsoft.com/en-us/powershell/module/exchange/mail-flow/set-remotedomain?view=exchange-ps

CIS Controls:

Version 7

7 Email and Web Browser Protections
Email and Web Browser Protections

ARCHIVE

4.5 (L1) Ensure mail transport rules do not whitelist specific domains (Automated)

Profile Applicability:

- E3 Level 1

Description:

You should set your Exchange Online mail transport rules so they do not whitelist any specific domains.

Rationale:

Whitelisting domains in transport rules bypasses regular malware and phishing scanning, which can enable an attacker to launch attacks against your users from a safe haven domain.

Audit:

To verify the mail transport rules do not whitelist any specific domains, use the Microsoft 365 Admin Center:

1. Select `Exchange`.
2. Select `Mail Flow` and `Rules`.
3. Review the rules and verify that none of them whitelist any specific domains.

To verify that mail transport rules do not whitelist any domains, you can also use the Exchange Online PowerShell:

1. Connect to Exchange online using Connect-EXOPSSession
2. Run the following PowerShell command:

```
Get-TransportRule | Where-Object {($_.setscl -eq -1 -and $_.SenderDomainIs -
ne $null)}  | ft Name,SenderDomainIs
```

ARCHIVE

Remediation:

To alter the mail transport rules so they do not whitelist any specific domains, use the Microsoft 365 Admin Center:

1. Select `Exchange`.
2. Select `Mail Flow` and `Rules`.
3. For each rule that whitelists specific domains, select the rule and click the 'Delete' icon.

To remove mail transport rules you may also use the Exchange Online PowerShell:

1. Connect to Exchange online using Connect-EXOPSSession
2. Run the following PowerShell command:

```
Remove-TransportRule {RuleName}
```

3. Verify the rules no longer exsist.

```
Get-TransportRule | Where-Object {($_.setscl -eq -1 -and $_.SenderDomainIs -
ne $null)}  | ft Name,SenderDomainIs
```

Impact:

Care should be taken before implementation to ensure there is no business need for case-by-case whitelisting. Removing all whitelisted domains could affect incoming mail flow to an organization although modern systems sending legitimate mail should have no issue with this.

CIS Controls:

Version 7

7 Email and Web Browser Protections
Email and Web Browser Protections

ARCHIVE

4.6 (L2) Ensure the Client Rules Forwarding Block is enabled (Automated)

Profile Applicability:

- E3 Level 2

Description:

You should enable the Client Rules Forwarding Block, which prevents the use of any client-side rules that forward email to an external domain.

Rationale:

The use of client-side forwarding rules to exfiltrate data to external recipients is an increasingly used vector for data exfiltration by bad actors.

Audit:

To verify the Client Rules Forwarding Block is enabled, use the Microsoft 365 Admin Center:

1. Go to `Exchange Admin Center`.
2. Select `mail flow`.
3. Select `Rules`.
4. Verify that 'Client Rules To External Block' exists.

To verify the Client Rules Forwarding Block is enabled, use the Exchange Online PowerShell Module:

1. Connect to Exchange Online using `Connect-EXOPSSession`.
2. Run the following Exchange Online PowerShell command:

```
Get-TransportRule | where { $_.Identity -like '*Client Rules To External
Block*' }
```

3. Verify that 'Client Rules To External Block' state is set to Enabled.

ARCHIVE

Remediation:

To create the Client Rules Forwarding Block, use the Exchange Online PowerShell Module:

1. Connect to Exchange Online using `Connect-EXOPSSession`.
2. Run the following Exchange Online PowerShell commands to create a rule:

```
$rejectMessageText = "To improve security, auto-forwarding rules to external
addresses has been disabled. Please contact your Microsoft Partner if you'd
like to set up an exception."

New-TransportRule -name "Client Rules To External Block" -Priority 0 -
SentToScope NotInOrganization -FromScope InOrganization -MessageTypeMatches
AutoForward -RejectMessageEnhancedStatusCode 5.7.1 -RejectMessageReasonText
$rejectMessageText
```

3. Verify that `Client Rules To External Block` gets created.

Impact:

Care should be taken before implementation to ensure there is no business need for case-by-case auto-forwarding. Disabling auto-forwarding to remote domains will affect all users and in an organization.

CIS Controls:

Version 7

7 Email and Web Browser Protections
Email and Web Browser Protections

ARCHIVE

4.7 (L2) Ensure the Advanced Threat Protection Safe Links policy is enabled (Automated)

Profile Applicability:

- E5 Level 2

Description:

Enabling the Advanced Threat Protection (ATP) Safe Links policy allows email messages that include URLs to be processed and rewritten if required. ATP Safe Links provides time-of-click verification of web addresses in email messages and Office documents.

Rationale:

ATP Safe Links extends phishing protection to include redirecting all email hyperlinks through a forwarding service which will block malicious ones even after the email has been delivered to the end user.

Audit:

To verify the ATP Safe Links policy is enabled, use the Microsoft 365 Admin Center:

1. Click `Security & Compliance` to open the Security & Compliance portal.
2. Navigate to `Threat management` > `Policy` > `ATP Safe Links`.
3. Under `Policies that apply to specific recipients`, verify that at least one policy exists and click `Edit`.
4. Select `Settings`.
5. Verify `Select the action for unknown potentially malicious URLs in messages` is set to `On`.
6. Verify that at least both `Do not let users click through safe links to original URL` and `Apply safe links to messages sent within the organization` are checked.

ARCHIVE

To verify the ATP Safe Links policy is enabled, use the Exchange Online PowerShell Module:

1. Connect using `Connect-EXOPSSession`.
2. Run the following PowerShell command:

```
Get-SafeLinksPolicy | Select-Object Name, IsEnabled, ScanUrls,
EnableForInternalSenders, AllowClickThrough
```

3. Verify the values for `IsEnabled` and `ScanUrls` are set to `True`, and `AllowClickThrough` is set to `False`.

Remediation:

To enable the ATP Safe Links policy, use the Microsoft 365 Admin Center:

1. Click `Security & Compliance` to open the Security & Compliance portal.
2. Navigate to `Threat management` > `Policy` > `ATP Safe Links`.
3. Under `Policies that apply to specific recipients`, verify that at least one policy exists and click `Edit`, or create a new policy.
4. Select `Settings`.
5. Select `On` for `Select the action for unknown potentially malicious URLs in messages`.
6. Check `Use safe attachments to scan downloadable content`.
7. Check `Apply safe links to messages sent within the organization`.
8. Check `Do not let users click through safe links to original URL`
9. Click `Save`.

To enable the ATP Safe Links policy, use the Exchange Online PowerShell Module:

1. Connect using `Connect-EXOPSSession`.
2. Run the following PowerShell command:

```
$SafeLinksPolicy = Get-SafeLinksPolicy

If (-not $SafeLinksPolicy.Identity) {
  $SafeLinksPolicy = New-SafeLinksPolicy -Name "Safe Links"
}

Set-SafeLinksPolicy -Identity $SafeLinksPolicy.Identity -IsEnabled $True -
ScanUrls $True -EnableForInternalSenders $True -AllowClickThrough $False
```

ARCHIVE

Impact:

When enabling and configuring ATP Safe Links impact to the end-user should be low. Users should be informed of the change as, in the event a link is unsafe and blocked, they will receive a message that it has been blocked.

Default Value:

disabled

References:

1. https://docs.microsoft.com/en-us/office365/securitycompliance/atp-safe-links
2. https://docs.microsoft.com/en-us/office365/securitycompliance/set-up-atp-safe-links-policies

Notes:

ATP Safe Links features are part of Advanced Threat Protection, which is included in Office 365 Enterprise E5, Microsoft 365 Business, and Microsoft 365 Enterprise.

CIS Controls:

Version 7

7.4 Maintain and Enforce Network-Based URL Filters

Enforce network-based URL filters that limit a system's ability to connect to websites not approved by the organization. This filtering shall be enforced for each of the organization's systems, whether they are physically at an organization's facilities or not.

ARCHIVE

4.8 (L2) Ensure the Advanced Threat Protection Safe Attachments policy is enabled (Automated)

Profile Applicability:

- E5 Level 2

Description:

Enabling the Advanced Threat Protection Safe Attachments policy extends malware protections to include routing all messages and attachments without a known malware signature to a special hypervisor environment. In that environment, a behavior analysis is performed using a variety of machine learning and analysis techniques to detect malicious intent.

Rationale:

This policy increases the likelihood of identifying and stopping previously unknown malware.

Audit:

To verify the ATP Safe Attachments policy is enabled, use the Microsoft 365 Admin Center:

1. Click `Security & Compliance` to open the Security & Compliance portal.
2. Navigate to `Threat management` > `Policy` > `ATP Safe Attachments`.
3. Verify that at least one policy exists.

To verify the ATP Safe Attachments policy is enabled, you can also use the Exchange Online PowerShell:

1. Connect to Exchange Online using Connect-EXOPSSession
2. Run the following PowerShell command:

```
Get-SafeAttachmentPolicy | where-object {$_.Enable -eq "True"}
```

ARCHIVE

Remediation:

To enable the ATP Safe Attachments policy, use the Microsoft 365 Admin Center:

1. Click `Security & Compliance` to open the Security & Compliance portal.
2. Navigate to `Threat management` > `Policy` > `ATP Safe Attach`.
3. Click `+`.
4. Enter Policy Name and Description.
5. Select `Block`, `Monitor` or `Dynamic Delivery`.
6. Select `Save`.

Impact:

Delivery of email with attachments may be delayed while scanning is occurring.

Default Value:

disabled

CIS Controls:

Version 7

7.10 Sandbox All Email Attachments
Use sandboxing to analyze and block inbound email attachments with malicious behavior.

8.1 Utilize Centrally Managed Anti-malware Software
Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.

ARCHIVE

4.9 (L2) Ensure basic authentication for Exchange Online is disabled (Automated)

Profile Applicability:

- E3 Level 2

Description:

Basic authentication may allow users to access Exchange Online using legacy or unapproved email clients that do not support modern authentication mechanisms, such as multifactor authentication.

Rationale:

Disabling basic authentication prevents use of legacy and unapproved email clients with weaker authentication mechanisms that would increase the risk of email account credential compromise.

Audit:

To verify basic authentication is disabled, use the Exchange Online PowerShell Module:

1. Run the Microsoft Exchange Online PowerShell Module.
2. Connect using `Connect-EXOPSSession`.
3. Run the following PowerShell command:

```
Get-OrganizationConfig | Select-Object -ExpandProperty
DefaultAuthenticationPolicy | ForEach { Get-AuthenticationPolicy $_ | Select-
Object AllowBasicAuth* }
```

4. Verify each of the basic authentication types is set to `false`. If no results are shown or an error is displayed, then no default authentication policy has been defined for your organization.
5. Verify Exchange Online users are configured to use the appropriate authentication policy (in this cause Block Basic Auth) by running the following PowerShell command:

```
Get-User -ResultSize Unlimited | Select-Object UserPrincipalName,
AuthenticationPolicy
```

ARCHIVE

Remediation:

To disable basic authentication, use the Exchange Online PowerShell Module:

1. Run the Microsoft Exchange Online PowerShell Module.
2. Connect using `Connect-EXOPSSession`.
3. Run the following PowerShell command:

*Note: If policy exists and command fails you may run `Remove-AuthenticationPolicy` first to ensure policy creation/application occurs as expected.

```
$AuthenticationPolicy = Get-OrganizationConfig | Select-Object
DefaultAuthenticationPolicy

If (-not $AuthenticationPolicy.Identity) {
  $AuthenticationPolicy = New-AuthenticationPolicy "Block Basic Auth";
  Set-OrganizationConfig -DefaultAuthenticationPolicy
$AuthenticationPolicy.Identity
}

Set-AuthenticationPolicy -Identity $AuthenticationPolicy.Identity -
AllowBasicAuthActiveSync:$false -AllowBasicAuthAutodiscover:$false -
AllowBasicAuthImap:$false -AllowBasicAuthMapi:$false -
AllowBasicAuthOfflineAddressBook:$false -AllowBasicAuthOutlookService:$false
-AllowBasicAuthPop:$false -AllowBasicAuthPowershell:$false -
AllowBasicAuthReportingWebServices:$false -AllowBasicAuthRpc:$false -
AllowBasicAuthSmtp:$false -AllowBasicAuthWebServices:$false

Get-User -ResultSize Unlimited | ForEach-Object { Set-User -Identity
$_.Identity -AuthenticationPolicy $AuthenticationPolicy.Identity -
STSRefreshTokensValidFrom $([System.DateTime]::UtcNow) }
```

Impact:

Blocking basic authentication will block the following legacy Exchange Online features:

- App passwords: An app password is a code that gives an app or device permission to access your Microsoft 365 account. If multi-factor authentication is enabled for your organization and you're using apps that connect to your Microsoft 365 account, you'll need to generate an app password so the app can connect to Microsoft 365. For example, if you're using Outlook 2016 or earlier with Microsoft 365, an app password is required.
- Availability address spaces: These contain a service account that's used to share calendar free/busy information in hybrid and federated deployments. The service account authenticates with a username and password, so blocking Basic authentication blocks the authentication flow.

Blocking basic authentication may also be accomplished via other methods such as conditional access.

Default Value:
false

References:

1. https://docs.microsoft.com/en-us/exchange/clients-and-mobile-in-exchange-online/disable-basic-authentication-in-exchange-online?redirectSourcePath=%252fen-us%252farticle%252fdisable-basic-authentication-in-exchange-online-bba2059a-7242-41d0-bb3f-baaf7ec1abd7

CIS Controls:

Version 7

7 Email and Web Browser Protections
Email and Web Browser Protections

16.3 Require Multi-factor Authentication
Require multi-factor authentication for all user accounts, on all systems, whether managed onsite or by a third-party provider.

ARCHIVE

4.10 (L1) Ensure that an anti-phishing policy has been created (Automated)

Profile Applicability:

- E5 Level 1

Description:

By default, Office 365 includes built-in features that help protect your users from phishing attacks. Set up anti-phishing polices to increase this protection, for example by refining settings to better detect and prevent impersonation and spoofing attacks. The default policy applies to all users within the organization, and is a single view where you can fine-tune anti-phishing protection. Custom policies can be created and configured for specific users, groups or domains within the organization and will take precedence over the default policy for the scoped users.

Rationale:

Protects users from phishing attacks (like impersonation and spoofing), and uses safety tips to warn users about potentially harmful messages.

Audit:

To review the anti-phishing policy, use the Microsoft 365 Admin Center:

1. Select `Security and Compliance`.
2. Expand `Threat Management` then select `Policy`.
3. Select `ATP Anti-phishing`.
4. Verify a policy exists.

To verify anti-phishing policy, use the Exchange Online PowerShell Module:

1. Connect to Exchange Online service using `Connect-EXOPSSession`.
2. Run the following Exchange Online PowerShell command:

```
Get-AntiPhishPolicy | ft Name
```

3. Verify `Office365 Antiphish Default` policy exists

ARCHIVE

Remediation:

To set the anti-phishing policy, use the Microsoft 365 Admin Center:

1. Select `Security and Compliance`.
2. Expand `Threat Management` then select `Policy`.
3. Select `ATP Anti-phishing`.
4. Click `Create` to create a anti-phishing policy.

To create anti-phishing policy, use the Exchange Online PowerShell Module:

1. Connect to Exchange Online service using `Connect-EXOPSSession`.
2. Run the following Exchange Online PowerShell command:

```
New-AntiPhishPolicy -Name "Office365 AntiPhish Policy"
```

Impact:

Turning on Anti-Phishing should not cause an impact, messages will be displayed when applicable.

CIS Controls:

Version 7

7 Email and Web Browser Protections
Email and Web Browser Protections

ARCHIVE

4.11 (L1) Ensure that DKIM is enabled for all Exchange Online Domains (Automated)

Profile Applicability:

- E3 Level 1

Description:

You should use DKIM in addition to SPF and DMARC to help prevent spoofers from sending messages that look like they are coming from your domain.

Rationale:

By enabling DKIM with Office 365, messages that are sent from Exchange Online will by cryptographically signed. This will allow the receiving email system to validate that the messages were generated by a server that the organization authorized and not being spoofed.

Audit:

To review if DKIM is enabled, use the Microsoft 365 Admin Center:

1. Select `Security and Compliance`.
2. Expand `Threat Management` then select `Policy`.
3. Click `DKIM`
4. Click on each domain and confirm that `Sign messages for this domain with DKIM signatures` is `Enabled`.

To verify DKIM is enabled, use the Exchange Online PowerShell Module:

1. Connect to Exchange Online service using `Connect-EXOPSSession`.
2. Run the following Exchange Online PowerShell command:

```
Get-DkimSigningConfig
```

3. Verify `Enabled` is set to True

ARCHIVE

Remediation:

To setup DKIM records, first add the following records to your DNS system, for each domain in Exchange Online that you plan to use to send email with:

1. For each accepted domain in Exchange Online, two DNS entries are required.

```
Host name:                      selector1._domainkey
Points to address or value:     selector1-
<domainGUID>._domainkey.<initialDomain>
TTL:                            3600
Host name:                      selector2._domainkey
Points to address or value:     selector2-
<domainGUID>._domainkey.<initialDomain>
TTL:                            3600
```

For Office 365, the selectors will always be `selector1` or `selector2`.
domainGUID is the same as the domainGUID in the customized MX record for your custom domain that appears before mail.protection.outlook.com. For example, in the following MX record for the domain contoso.com, the domainGUID is contoso-com:

```
contoso.com.  3600  IN  MX   5 contoso-com.mail.protection.outlook.com
```

initialDomain is the domain that you used when you signed up for Office 365. Initial domains always end in on microsoft.com.

2. After the DNS records are created, enable DKIM signing in the Office 365 Admin Portal
3. Launch the `Security & Compliance` Admin Center.
4. Expand `Threat Management` then select `Policy`.
5. Click `DKIM`.
6. Click on each domain and click `Enable` next to `Sign messages for this domain with DKIM signature`.

To set DKIM is enabled, use the Exchange Online PowerShell Module:

1. Connect to Exchange Online service using `Connect-EXOPSSession`.
2. Run the following Exchange Online PowerShell command:

```
Set-DkimSigningConfig -Identity < domainName > -Enabled $True
```

Impact:

There should be no impact of setting up DKIM however, organizations should ensure appropriate setup to ensure continuous mail-flow.

References:

1. https://docs.microsoft.com/en-us/office365/SecurityCompliance/use-dkim-to-validate-outbound-email

CIS Controls:

Version 7

7.8 Implement DMARC and Enable Receiver-Side Verification

To lower the chance of spoofed or modified emails from valid domains, implement Domain-based Message Authentication, Reporting and Conformance (DMARC) policy and verification, starting by implementing the Sender Policy Framework (SPF) and the DomainKeys Identified Mail(DKIM) standards.

ARCHIVE

4.12 (L1) Ensure that SPF records are published for all Exchange Domains (Manual)

Profile Applicability:

- E3 Level 1

Description:

For each domain that is configured in Exchange, a corresponding Sender Policy Framework (SPF) record should be created.

Rationale:

SPF records allow Exchange Online Protection and other mail systems know where messages from your domains are allowed to originate. This information can be used to by that system to determine how to treat the message based on if it is being spoofed or is valid.

Audit:

To verify that SPF records are published for each Exchange Online Domain, do the following:

1. Open a command prompt.
2. Type the following command:

```
nslookup -type=txt domain1.com
```

3. Ensure that a value exists and that it includes `include:spf.protection.outlook.com`. This designates Exchange Online as a designated sender.

To verify the SPF records are published, use the REST API for each domain:

```
https://graph.microsoft.com/v1.0/domains/[DOMAIN.COM]/serviceConfigurationRec
ords
```

1. Ensure that a value exists that includes `include:spf.protection.outlook.com`. This designates Exchange Online as a designated sender.

ARCHIVE

Remediation:

To setup SPF records for Exchange Online accepted domains, perform the following steps:

1. If all email in your domain is sent from and received by Exchange Online, add the following TXT record for each Accepted Domain:

```
v=spf1 include:spf.protection.outlook.com -all
```

2. If there are other systems that send email in the environment, refer to this article for the proper SPF configuration: https://docs.microsoft.com/en-us/office365/SecurityCompliance/set-up-spf-in-office-365-to-help-prevent-spoofing.

Impact:

There should be minimal impact of setting up SPF records however, organizations should ensure proper SPF record setup as email could be flagged as spam if SPF is not setup appropriately.

References:

1. https://docs.microsoft.com/en-us/office365/SecurityCompliance/set-up-spf-in-office-365-to-help-prevent-spoofing

CIS Controls:

Version 7

7.8 Implement DMARC and Enable Receiver-Side Verification

To lower the chance of spoofed or modified emails from valid domains, implement Domain-based Message Authentication, Reporting and Conformance (DMARC) policy and verification, starting by implementing the Sender Policy Framework (SPF) and the DomainKeys Identified Mail(DKIM) standards.

ARCHIVE

4.13 (L1) Ensure DMARC Records for all Exchange Online domains are published (Manual)

Profile Applicability:

- E3 Level 1

Description:

Publish Domain-Based Message Authentication, Reporting and Conformance (DMARC) records for each Exchange Online Accepted Domain.

Rationale:

Domain-based Message Authentication, Reporting and Conformance (DMARC) work with Sender Policy Framework (SPF) and DomainKeys Identified Mail (DKIM) to authenticate mail senders and ensure that destination email systems trust messages sent from your domain.

Audit:

To verify that DMARC records are published, perform the following steps:

1. Open a command prompt.
2. For each of the Accepted Domains in Exchange Online type the following command:

```
nslookup -type=txt _dmarc.domain1.com
```

3. Ensure that a policy exists that starts with `v=DMARC1;`.

Remediation:

To add DMARC records, use the following steps:

1. For each Exchange Online Accepted Domain, add the following record to DNS:

```
Record:  _dmarc.domain1.com
Type:  TXT
Value:  v=DMARC1; p=none;
```

2. This will create a basic DMARC policy that audits compliance

ARCHIVE

Impact:

There should be no impact of setting up DMARC however, organizations should ensure appropriate setup to ensure continuous mail-flow.

References:

1. https://docs.microsoft.com/en-us/office365/SecurityCompliance/use-dmarc-to-validate-email#CreateDMARCRecord

CIS Controls:

Version 7

7.8 Implement DMARC and Enable Receiver-Side Verification

To lower the chance of spoofed or modified emails from valid domains, implement Domain-based Message Authentication, Reporting and Conformance (DMARC) policy and verification, starting by implementing the Sender Policy Framework (SPF) and the DomainKeys Identified Mail(DKIM) standards.

ARCHIVE

4.14 (L1) Ensure notifications for internal users sending malware is Enabled (Automated)

Profile Applicability:

- E3 Level 1

Description:

Setup the EOP malware filter to notify administrators if internal senders are blocked for sending malware.

Rationale:

This setting alerts administrators that an internal user sent a message that contained malware. This may indicate an account or machine compromise, that would need to be investigated.

Audit:

To verify notifications for internal users sending malware is enabled, use the Microsoft 365 Admin Center:

1. Launch the `Security & Compliance Admin Center`.
2. Expand `Threat Management` then select `Policy`.
3. Select `Anti-malware`.
4. Ensure the setting `Notify administrator about undelivered messages from internal senders` is `checked` and that there is at least one email address under `Administrator email address`.

To check the setting from PowerShell, use the Exchange Online Module for PowerShell

1. Connect to Exchange Online by using the `connect-exopssession commandlet`.
2. Run the following command:

```
Get-MalwareFilterPolicy | fl Identity,
EnableInternalSenderAdminNotifications, InternalSenderAdminAddress
```

ARCHIVE

Remediation:

To enable notifications for internal users sending malware, use the Microsoft 365 Admin Center:

1. Launch the `Security & Compliance Admin Center`.
2. Expand `Threat Management` then select `Policy`.
3. Select `Anti-malware`.
4. Check the setting `Notify administrator about undelivered messages from internal senders` and enter the email address of the administrator who should be notified under `Administrator email address`.

To check the setting from PowerShell, use the Exchange Online Module for PowerShell

1. Connect to Exchange Online by using the `connect-exopssession` commandlet.
2. Run the following command:

```
set-MalwareFilterPolicy -Identity '{Identity Name}' -
EnableInternalSenderAdminNotifications $True -InternalSenderAdminAddress
{admin@domain1.com}
```

Impact:

Notification of account with potential issues should not cause an impact to the user.

CIS Controls:

Version 7

7.1 Ensure Use of Only Fully Supported Browsers and Email Clients
Ensure that only fully supported web browsers and email clients are allowed to execute in the organization, ideally only using the latest version of the browsers and email clients provided by the vendor.

8.1 Utilize Centrally Managed Anti-malware Software
Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.

ARCHIVE

4.15 (L2) Ensure MailTips are enabled for end users (Automated)

Profile Applicability:

- E3 Level 2

Description:

MailTips assist end users with identifying strange patterns to emails they send

Rationale:

Setting up MailTips gives a visual aid to users when they send emails to large groups of recipients or send emails to recipients not within the tenant.

Audit:

To verify MailTips are enabled, use the Exchange Online PowerShell Module:

1. Run Microsoft Exchange Online PowerShell Module
2. Connect using `Connect-EXOPSSession`
3. Run the following PowerShell command:

```
Get-OrganizationConfig |Select-Object MailTipsAllTipsEnabled,
MailTipsExternalRecipientsTipsEnabled, MailTipsGroupMetricsEnabled,
MailTipsLargeAudienceThreshold
```

4. Verify the values for `MailTipsAllTipsEnabled`, `MailTipsExternalRecipientsTipsEnabled`, and `MailTipsGroupMetricsEnabled` are set to `True` and `MailTipsLargeAudienceThreshold` is set to an acceptable value; `25` is the default value.

Remediation:

To enable MailTips, use the Exchange Online PowerShell Module:

1. Run Microsoft Exchange Online PowerShell Module
2. Connect using `Connect-EXOPSSession`
3. Run the following PowerShell command:

```
Set-OrganizationConfig -MailTipsAllTipsEnabled $true -
MailTipsExternalRecipientsTipsEnabled $true -MailTipsGroupMetricsEnabled
$true -MailTipsLargeAudienceThreshold '25'
```

ARCHIVE

Default Value:

MailTipsAllTipsEnabled: True MailTipsExternalRecipientsTipsEnabled: False MailTipsGroupMetricsEnabled: True MailTipsLargeAudienceThreshold: 25

CIS Controls:

Version 7

7 Email and Web Browser Protections
Email and Web Browser Protections

13 Data Protection
Data Protection

ARCHIVE

4.16 (L2) Ensure that LinkedIn contact synchronization is disabled. (Automated)

Profile Applicability:

- E3 Level 2

Description:

You should disable integration with LinkedIn as a measure to help prevent phishing scams.

Rationale:

Office 365 is the prime target of phishing scams. Phishing attacks are a subset of social engineering strategy that imitate a trusted source and concoct a seemingly logical scenario for handing over sensitive information. Social networking sites have made social engineering attacks easier to conduct.

LinkedIn integration is enabled by default in Office 365 that could lead to a risk scenario where an external party could be accidentally disclosed sensitive information.

Audit:

To verify that LinkedIn contacts synchronization is disabled, perform the following steps from Exchange Online PowerShell:

1. Use Microsoft Explorer or Edge then navigate to `https://admin.microsoft.com` and login as a Global Admin.
2. Expand `Admin centers` then select `Exchange`.
3. Once the Exchange Admin center is open select `hybrid`
4. Select `configure` to install the `Exchange Online PowerShell module`.
5. In the PowerShell window, enter the following command

```
Connect-EXOPSSession -UserPrincipalName xxx@somecompany.com
```

6. To check if LinkedIn integration is enabled enter the following command

```
Get-OwaMailboxPolicy | select LinkedInEnabled
```

7. Verify that the value of `LinkedInEnabled` is set to `False`.

ARCHIVE

Remediation:

To disable LinkedIn contacts synchronization, perform the following steps from Exchange Online PowerShell:

1. Use Microsoft Explorer or Edge then navigate to `https://admin.microsoft.com` and login as a Global Admin.
2. Expand `Admin centers` then select `Exchange`.
3. Once the Exchange Admin center is open select `hybrid`
4. Select `configure` to install the `Exchange Online PowerShell module`.
5. In the PowerShell window, enter the following command

```
Connect-EXOPSSession -UserPrincipalName xxx@somecompany.com
```

6. To disable LinkedIn integration enter the following command

```
Set-OwaMailboxPolicy -Identity OwaMailboxPolicy-Default -LinkedInEnabled
$False
```

7. Verify that the value of `LinkedInEnabled` is now set to `False` run the following command.

```
Get-OwaMailboxPolicy | select LinkedInEnabled
```

Impact:

Users will not be able to sync contacts or use LinkedInintegration.

Default Value:

LinkedIn integration is enabled by default.

References:

1. https://docs.microsoft.com/en-us/powershell/module/exchange/client-access/set-owamailboxpolicy?view=exchange-ps

CIS Controls:

Version 7

13.3 Monitor and Block Unauthorized Network Traffic

Deploy an automated tool on network perimeters that monitors for unauthorized transfer of sensitive information and blocks such transfers while alerting information security professionals.

ARCHIVE

4.17 (L2) Ensure that Facebook contact synchronization is disabled. (Automated)

Profile Applicability:

- E3 Level 2

Description:

You should disable integration with Facebook as a measure to help prevent phishing scams.

Rationale:

Office 365 is the prime target of phishing scams. Phishing attacks are a subset of social engineering strategy that imitate a trusted source and concoct a seemingly logical scenario for handing over sensitive information. Social networking sites have made social engineering attacks easier to conduct.

Facebook integration is enabled by default in Office 365 that could lead to a risk scenario where an external party could be accidentally disclosed sensitive information.

Audit:

To verify that Facebook contacts synchronization is disabled, perform the following steps from Exchange Online PowerShell:

1. Use Microsoft Explorer or Edge then navigate to `https://admin.microsoft.com` and login as a Global Admin.
2. Expand `Admin centers` then select `Exchange`.
3. Once the Exchange Admin center is open select `hybrid`
4. Select `configure` to install the `Exchange Online PowerShell module`.
5. In the PowerShell window, enter the following command

```
Connect-EXOPSSession -UserPrincipalName xxx@somecompany.com
```

6. To check if Facebook integration is enabled enter the following command

```
Get-OwaMailboxPolicy | select FacebookEnabled
```

7. Verify that the value of `FacebookEnabled` is set to `False`.

ARCHIVE

Remediation:

To disable Facebook contacts synchronization, perform the following steps from Exchange Online PowerShell:

1. Use Microsoft Explorer or Edge then navigate to `https://admin.microsoft.com` and login as a Global Admin.
2. Expand `Admin centers` then select `Exchange`.
3. Once the Exchange Admin center is open select `hybrid`
4. Select `configure` to install the `Exchange Online PowerShell module`.
5. In the PowerShell window, enter the following command

```
Connect-EXOPSSession -UserPrincipalName xxx@somecompany.com
```

6. To disable Facebook integration enter the following command

```
Set-OwaMailboxPolicy -Identity OwaMailboxPolicy-Default -DisableFacebook
```

7. Verify that the value of `FacebookEnabled` is now set to `False` run the following command.

```
Get-OwaMailboxPolicy | select FacebookEnabled
```

Impact:

Users will not be able to sync contacts or use Facebook integration.

Default Value:

Facebook integration is enabled by default.

References:

1. https://docs.microsoft.com/en-us/powershell/module/exchange/client-access/set-owamailboxpolicy?view=exchange-ps

CIS Controls:

Version 7

13.3 Monitor and Block Unauthorized Network Traffic

Deploy an automated tool on network perimeters that monitors for unauthorized transfer of sensitive information and blocks such transfers while alerting information security professionals.

ARCHIVE

5 Auditing

5.1 (L1) Ensure Microsoft 365 audit log search is Enabled (Automated)

Profile Applicability:

- E3 Level 1

Description:

When audit log search in the Microsoft 365 Security & Compliance Center is enabled, user and admin activity from your organization is recorded in the audit log and retained for 90 days. However, your organization might be using a third-party security information and event management (SIEM) application to access your auditing data. In that case, a global admin can turn off audit log search in Microsoft 365.

Rationale:

Enabling Microsoft 365 audit log search helps Office 365 back office teams to investigate activities for regular security operational or forensic purposes.

Audit:

To verify Microsoft 365 audit log search is enabled, use the Microsoft 365 Admin Center:

1. Log in as an administrator.
2. Navigate to the `Office 365 security & compliance center` by going to https://protection.office.com
3. In the Security & Compliance Center, expand `Search` then select `Audit log search`.
4. Verify that you are able to do searches (e.g. try searching for Activities as `Accessed file` and results should be displayed).

ARCHIVE

To verify Microsoft 365 audit log search is enabled, use the Exchange Online PowerShell Module:

1. Run Microsoft Exchange Online PowerShell Module.
2. Connect using `Connect-EXOPSSession`.
3. Run the following PowerShell command:

```
Get-AdminAuditLogConfig | Select-Object AdminAuditLogEnabled,
UnifiedAuditLogIngestionEnabled
```

4. Verify the resulting values are `true`.

Remediation:

To enable Microsoft 365 audit log search, use the Microsoft 365 Admin Center:

1. Log in as an administrator.
2. Navigate to the `Office 365 security & compliance center` by going to https://protection.office.com
3. In the Security & Compliance Center, expand `Search` then select `Audit log search`.
4. Click `Start recording user and admin activities` next to the information warning at the top.
5. Click `Yes` on the dialog box to confirm.

To enable Microsoft 365 audit log search, use the Exchange Online PowerShell Module:

1. Run Microsoft Exchange Online PowerShell Module.
2. Connect using `Connect-EXOPSSession`.
3. Run the following PowerShell command:

```
Set-AdminAuditLogConfig -AdminAutidLogEnabled $true -
UnifiedAuditLogIngestionEnabled $true
```

A message is displayed saying that it might take up to 60 minutes for the change to take effect. If an error appears, you may need to run `Enable-OrganizationCustomization` before disconnecting and trying the command again.

ARCHIVE

Default Value:

disabled

References:

1. https://docs.microsoft.com/en-us/office365/securitycompliance/turn-audit-log-search-on-or-off

CIS Controls:

Version 7

6.2 Activate audit logging
Ensure that local logging has been enabled on all systems and networking devices.

ARCHIVE

5.2 (L1) Ensure mailbox auditing for all users is Enabled (Automated)

Profile Applicability:

- E3 Level 1

Description:

By turning on mailbox auditing, Microsoft 365 back office teams can track logons to a mailbox as well as what actions are taken while the user is logged on. After you turn on mailbox audit logging for a mailbox, you can search the audit log for mailbox activity. Additionally, when mailbox audit logging is turned on, some actions performed by administrators, delegates, and owners are logged by default.

Rationale:

Starting in January 2019, Microsoft is turning on mailbox audit logging by default for all organizations. This means that certain actions performed by mailbox owners, delegates, and admins are automatically logged, and the corresponding mailbox audit records will be available when you search for them in the mailbox audit log. When mailbox auditing on by default is turned on for the organization, the AuditEnabled property for affected mailboxes won't be changed from False to True. In other words, mailbox auditing on by default ignores the AuditEnabled property on mailboxes. However, only certain mailbox types support default auditing `On`

- User Mailboxes
- Shared Mailboxes
- Microsoft 365 Group Mailboxes

The remaining mailbox types require auditing be turned on at the mailbox level:

- Resource Mailboxes
- Public Folder Mailboxes
- DiscoverySearch Mailbox

Whether it is for regulatory compliance or for tracking unauthorized configuration changes in Microsoft 365, enabling mailbox auditing allows for Microsoft 365 back office teams to run security operations, forensics or general investigations on mailbox activities.

ARCHIVE

Audit:

To verify mailbox auditing is enabled by default, use the Exchange Online PowerShell Module:

1. Run Microsoft Exchange Online PowerShell Module.
2. Connect using `Connect-EXOPSSession`.
3. Run the following PowerShell command:

```
Get-OrganizationConfig | Format-List AuditDisabled
```

4. Verify `AuditDisabled` is set to `False`.

To verify mailbox auditing is enabled for all mailboxes that don't support default auditing, use the Exchange Online PowerShell Module:

1. Run Microsoft Exchange Online PowerShell Module.
2. Connect using `Connect-EXOPSSession`.
3. Run the following PowerShell command:

```
Get-Mailbox -ResultSize Unlimited | Where-Object {$_.AuditEnabled -ne $true -
and ($_.RecipientTypeDetails -ne "UserMailbox" -or $_.RecipientTypeDetails -
ne "SharedMailbox")}
```

Alternatively you may run the following command:

```
Get-mailbox | Where AuditEnabled -Match 'False' | select UserPrincipalName,
auditenabled
```

4. Verify `AuditEnabled` is set to `True` for all mailboxes that are not a user, shared, or group mailbox.

ARCHIVE

Remediation:

To enable mailbox auditing for all users, use the Exchange Online PowerShell Module:

1. Run Microsoft Exchange Online PowerShell Module.
2. Connect using `Connect-EXOPSSession`.
3. Run the following PowerShell commands:

```
$AuditAdmin = @("Copy", "Create", "FolderBind",
"HardDelete", "MessageBind", "Move", "MoveToDeletedItems", "SendAs",
"SendOnBehalf", "SoftDelete", "Update", "UpdateCalendarDelegation",
"UpdateFolderPermissions", "UpdateInboxRules")

$AuditDelegate =
@("Create", "FolderBind", "HardDelete", "Move", "MoveToDeletedItems", "SendAs
", "SendOnBehalf", "SoftDelete", "Update", "UpdateFolderPermissions", "Update
InboxRules")

$AdminOwner =
@("Create", "HardDelete", "MailboxLogin", "Move", "MoveToDeletedItems", "Soft
Delete", "Update", "UpdateCalendarDelegation",
"UpdateFolderPermissions", "UpdateInboxRules")

Get-Mailbox -ResultSize Unlimited | Set-Mailbox -AuditEnabled $true -
AuditLogAgeLimit 180 -AuditAdmin $AuditAdmin -AuditDelegate $AuditDelegate -
AuditOwner $AuditOwner
```

Default Value:

Only certain mailbox types support default auditing `On`:

- User Mailboxes
- Shared Mailboxes
- Microsoft 365 Group Mailboxes

The remaining mailbox types require auditing be turned on at the mailbox level:

- Resource Mailboxes
- Public Folder Mailboxes
- DiscoverySearch Mailbox

References:

1. https://docs.microsoft.com/en-us/microsoft-365/compliance/enable-mailbox-auditing?view=o365-worldwide

CIS Controls:

Version 7

6.2 Activate audit logging
Ensure that local logging has been enabled on all systems and networking devices.

ARCHIVE

5.3 (L1) Ensure the Azure AD 'Risky sign-ins' report is reviewed at least weekly (Manual)

Profile Applicability:

- E3 Level 1

Description:

This report contains records of accounts that have had activity that could indicate they are compromised, such as accounts that have: -successfully signed in after multiple failures, which is an indication that the accounts have cracked passwords -signed in to your tenancy from a client IP address that has been recognized by Microsoft as an anonymous proxy IP address (such as a TOR network) -successful signins from users where two signins appeared to originate from different regions and the time between signins makes it impossible for the user to have traveled between those regions

Rationale:

Reviewing this report on a regular basis allows for identification and remediation of compromised accounts.

Audit:

To verify the report is being reviewed at least weekly, confirm that the necessary procedures are in place and being followed.

Remediation:

To review the report, perform the following steps using the Azure Portal:

1. Go to portal.azure.com.
2. Click `Azure Active Directory`.
3. Select `Risk events`.
4. Review by `Detection Type`.

To get risky sign-ins event report programatically, use following graph API:

```
https://graph.microsoft.com/beta/identityRiskEvents?$filter=riskEventDateTime
gt < 7 days older datetime > and riskEventStatus eq 'active'
```

ARCHIVE

References:

1. https://docs.microsoft.com/en-us/azure/active-directory/reports-monitoring/concept-user-at-risk
2. https://docs.microsoft.com/en-us/azure/active-directory/reports-monitoring/howto-remediate-users-flagged-for-risk

CIS Controls:

Version 7

6.2 Activate audit logging
Ensure that local logging has been enabled on all systems and networking devices.

ARCHIVE

5.4 (L2) Ensure the Application Usage report is reviewed at least weekly (Manual)

Profile Applicability:

- E3 Level 2

Description:

You should review the Application Usage report at least weekly. This report includes a usage summary for all Software As A Service (SaaS) applications that are integrated with your directory.

Rationale:

Review the list of app registrations on a regular basis to look for risky apps that users have enabled that could cause data spillage or accidental elevation of privilege. Attackers can often get access to data illicitly through third-party SaaS applications.

Audit:

To verify the report is being reviewed at least weekly, confirm that the necessary procedures are in place and being followed.

Remediation:

To review the report, perform the following steps using the Azure Portal:

1. Go to portal.azure.com.
2. Click `Azure Active Directory`.
3. Select `Enterprise applications`.
4. Review the information.

CIS Controls:

Version 7

6.2 Activate audit logging
Ensure that local logging has been enabled on all systems and networking devices.

ARCHIVE

5.5 (L1) Ensure the self-service password reset activity report is reviewed at least weekly (Manual)

Profile Applicability:

- E3 Level 1

Description:

The Microsoft 365 platforms allow a user to reset their password in the event they forget it. The self-service password reset activity report logs each time a user successfully resets their password this way. You should review the self-service password reset activity report at least weekly.

Rationale:

An attacker will commonly compromise an account, then change the password to something they control and can manage.

Audit:

To verify the report is being reviewed at least weekly, confirm that the necessary procedures are in place and being followed.

Remediation:

To review the report, perform the following steps using the Azure Portal:

1. Go to portal.azure.com.
2. Go to 'Azure Active Directory'.
3. Click on 'Usage & insights' under 'Monitoring'.
4. Select 'Authentication methods activity' and the 'Usage' tab.
5. Review the list of users who have reset their passwords in the last seven days by clicking 'Self-service password resets and account unlocks by method'.

CIS Controls:

Version 7

6.2 <u>Activate audit logging</u>
Ensure that local logging has been enabled on all systems and networking devices.

ARCHIVE

5.6 (L1) Ensure user role group changes are reviewed at least weekly (Manual)

Profile Applicability:

- E3 Level 1

Description:

User role group changes should be reviewed on a weekly basis to ensure no one has been improperly added to an administrative role.

Rationale:

Illicit role group changes could give an attacker elevated privileges to perform more dangerous and impactful things in your tenancy.

Audit:

To verify user role group changes are being reviewed at least weekly, confirm that the necessary procedures are in place and being followed.

Remediation:

To review user role group changes, perform the following steps using the Microsoft 365 Admin Center:

1. Go to `Security and Compliance Center`.
2. Expand `Search` then select `Audit Log Search`.
3. Set `Activities` to `Added member to role`.
4. Set `Start Date` and `End Date`.
5. Click `Search`.
6. Review.

ARCHIVE

To review user role group changes, perform the following steps using Exchange Online PowerShell Module:

1. Connect to Exchange Online using `Connect-EXOPSSession`.
2. Run the following Exchange Online PowerShell command:

```
$startDate = ((Get-date).AddDays(-7)).ToShortDateString()
$endDate = (Get-date).ToShortDateString()

Search-UnifiedAuditLog -StartDate $startDate -EndDate $endDate | Where-Object
{ $_.Operations -eq "Add member to role." }
```

3. Review the output

CIS Controls:

Version 7

6.2 Activate audit logging
Ensure that local logging has been enabled on all systems and networking devices.

ARCHIVE

5.7 (L1) Ensure mail forwarding rules are reviewed at least weekly (Manual)

Profile Applicability:

- E3 Level 1

Description:

You should review mail forwarding rules to external domains at least every week.

Rationale:

While there are lots of legitimate uses of mail forwarding rules, they are also a popular data exfiltration tactic for attackers. You should review them regularly to ensure your users' email is not being exfiltrated.

Audit:

To verify mail forwarding rules are being reviewed at least weekly, confirm that the necessary procedures are in place and being followed.

Remediation:

To review mail forwarding rules, use the Microsoft 365 Admin Center:

1. Go to `Security and Compliance Center`.
2. Expand `Mail Flow` and then `Dashboard`.
3. Review `Auto Forwarded Messages` on the dashboard.

ARCHIVE

To review mail forwarding rules, use the following Powershell script:
Uses the administrator user credential to export Mail forwarding rules, User Delegates and SMTP Forwarding policies to multiple csv files. First connect to Exchange Online by using `connect-exopssession`

```
$allUsers = @()
$AllUsers = Get-MsolUser -All -EnabledFilter EnabledOnly | select ObjectID,
UserPrincipalName, FirstName, LastName, StrongAuthenticationRequirements,
StsRefreshTokensValidFrom, StrongPasswordRequired,
LastPasswordChangeTimestamp | Where-Object {($_.UserPrincipalName -notlike
"*#EXT#*")}


$UserInboxRules = @()
$UserDelegates = @()


foreach ($User in $allUsers)
{
    Write-Host "Checking inbox rules and delegates for user: "
$User.UserPrincipalName;
    $UserInboxRules += Get-InboxRule -Mailbox $User.UserPrincipalname |
Select Name, Description, Enabled, Priority, ForwardTo,
ForwardAsAttachmentTo, RedirectTo, DeleteMessage | Where-Object
{($_.ForwardTo -ne $null) -or ($_.ForwardAsAttachmentTo -ne $null) -or
($_.RedirectsTo -ne $null)}
    $UserDelegates += Get-MailboxPermission -Identity $User.UserPrincipalName
| Where-Object {($_.IsInherited -ne "True") -and ($_.User -notlike "*SELF*")}
}


$SMTPForwarding = Get-Mailbox -ResultSize Unlimited | select
DisplayName,ForwardingAddress,ForwardingSMTPAddress,DeliverToMailboxandForwar
d | where {$_.ForwardingSMTPAddress -ne $null}

# Export list of inboxRules, Delegates and SMTP Forwards
$UserInboxRules | Export-Csv MailForwardingRulesToExternalDomains.csv
$UserDelegates | Export-Csv MailboxDelegatePermissions.csv
$SMTPForwarding | Export-Csv Mailboxsmtpforwarding.csv
```

CIS Controls:

Version 7

6.2 Activate audit logging
Ensure that local logging has been enabled on all systems and networking devices.

5.8 (L1) Ensure the Mailbox Access by Non-Owners Report is reviewed at least biweekly (Manual)

Profile Applicability:

- E3 Level 1

Description:

You should review the Mailbox Access by Non-Owners report at least every other week. This report shows which mailboxes have been accessed by someone other than the mailbox owner.

Rationale:

While there are many legitimate uses of delegate permissions, regularly reviewing that access can help prevent an external attacker from maintaining access for a long time, and can help discover malicious insider activity sooner.

Audit:

To verify the report is being reviewed at least biweekly, confirm that the necessary procedures are in place and being followed.

Remediation:

To review the report, perform the following steps using the Microsoft 365 Admin Center:

1. Click `Exchange`.
2. Click `Compliance Management` and `auditing`.
3. Select `Run a non-owner mailbox access report`.
4. Enter `Start Date` and `End Date`.
5. Change `Search for access by` field to `all non-owners`.
6. Select `Search`.

ARCHIVE

CIS Controls:

Version 7

6.2 Activate audit logging
Ensure that local logging has been enabled on all systems and networking devices.

ARCHIVE

5.9 (L1) Ensure the Malware Detections report is reviewed at least weekly (Manual)

Profile Applicability:

- E3 Level 1

Description:

You should review the Malware Detections report at least weekly. This report shows specific instances of Microsoft blocking a malware attachment from reaching your users.

Rationale:

While this report isn't strictly actionable, reviewing it will give you a sense of the overall volume of malware being targeted at your users, which may prompt you to adopt more aggressive malware mitigations.

Audit:

To verify the report is being reviewed at least weekly, confirm that the necessary procedures are in place and being followed.

Remediation:

To review the report, use the Microsoft 365 Admin Center:

1. Select `Security and Compliance`.
2. Expand `Reports` then select `Dashboard`.
3. Review the `Malware Detected in Email` report.

CIS Controls:

Version 7

6.2 Activate audit logging
Ensure that local logging has been enabled on all systems and networking devices.

ARCHIVE

5.10 (L1) Ensure the Account Provisioning Activity report is reviewed at least weekly (Manual)

Profile Applicability:

- E3 Level 1

Description:

The Account Provisioning Activity report details any account provisioning that was attempted by an external application.

Rationale:

If you don't usually use a third party provider to manage accounts, any entry on the list is likely illicit. If you do, this is a great way to monitor transaction volumes and look for new or unusual third party applications that are managing users. If you see something unusual, contact the provider to determine if the action is legitimate.

Audit:

To verify the report is being reviewed at least weekly, confirm that the necessary procedures are in place and being followed.

Remediation:

To review the report, use the Microsoft 365 Admin Center:

1. Go to `Security and Compliance Center`.
2. Expand `Search` then select `Audit Log Search`.
3. Set `Activities` to `Added user`.
4. Set `Start Date` and `End Date`.
5. Click `Search`.
6. Review.

ARCHIVE

To review Account Provisioning Activity report, use the Exchange Online PowerShell Module:

1. Connect to Exchange Online service using `Connect-EXOPSSession`.
2. Run the following Exchange Online PowerShell command:

```
$startDate = ((Get-date).AddDays(-7)).ToShortDateString()
$endDate = (Get-date).ToShortDateString()

Search-UnifiedAuditLog -StartDate $startDate -EndDate $endDate | Where-Object
{ $_.Operations -eq "add user." }
```

3. Review the output

CIS Controls:

Version 7

6.2 Activate audit logging
Ensure that local logging has been enabled on all systems and networking devices.

ARCHIVE

5.11 (L1) Ensure non-global administrator role group assignments are reviewed at least weekly (Manual)

Profile Applicability:

- E3 Level 1

Description:

You should review non-global administrator role group assignments at least every week.

Rationale:

While these roles are less powerful than a global admin, they do grant special privileges that can be used illicitly. If you see something unusual, contact the user to confirm it is a legitimate need.

Audit:

To verify non-global administrator role group assignments are being reviewed at least weekly, confirm that the necessary procedures are in place and being followed.

Remediation:

To review non-global administrator role group assignments, use the Microsoft 365 Admin Center:

1. Go to `Security and Compliance Center`.
2. Expand`Search` then select `Audit Log Search`.
3. Set `Added member to Role` and `Removed a user from a directory role`
4. Set `Start Date` and `End Date`.
5. Click `Search`.
6. Review.

CIS Controls:

Version 7

6.2 <u>Activate audit logging</u>
Ensure that local logging has been enabled on all systems and networking devices.

ARCHIVE

5.12 (L1) Ensure the spoofed domains report is review weekly (Manual)

Profile Applicability:

- E5 Level 1

Description:

Use spoof intelligence in the Security & Compliance Center on the Anti-spam settings page to review all senders who are spoofing either domains that are part of your organization, or spoofing external domains. Spoof intelligence is available as part of Office 365 Enterprise E5 or separately as part of Advanced Threat Protection (ATP) and as of October, 2018 Exchange Online Protection (EOP).

Rationale:

Bad actors spoof domains to trick users into conducting actions they normally would not or should not via phishing emails.

Audit:

To verify the report is being reviewed at least weekly, confirm that the necessary procedures are in place and being followed.

Remediation:

To review the report, use the Microsoft 365 Admin Center:

1. Go to `Security and Compliance Center`.
2. Expand `Threat Management` then select `Dashboard`.
3. Click `Spoofed domains that failed authentication over the past 30 days`.
4. Review.

To verify mailbox auditing is enabled for all users, use the Exchange Online PowerShell Module:

1. Connect to Exchange Online using `Connect-EXOPSSession`.
2. Run the following PowerShell command:

```
Get-PhishFilterPolicy -Detailed -SpoofAllowBlockList -SpoofType Internal
```

3. Review.

ARCHIVE

CIS Controls:

Version 7

6.2 Activate audit logging
Ensure that local logging has been enabled on all systems and networking devices.

ARCHIVE

5.13 (L2) Ensure Microsoft 365 Cloud App Security is Enabled (Manual)

Profile Applicability:

- E3 Level 1

Description:

Enabling Microsoft 365 Cloud App Security gives you insight into suspicious activity in Microsoft 365 so you can investigate situations that are potentially problematic and, if needed, take action to address security issues.

Rationale:

You can receive notifications of triggered alerts for atypical or suspicious activities, see how your organization's data in Microsoft 365 is accessed and used, suspend user accounts exhibiting suspicious activity, and require users to log back in to Microsoft 365 apps after an alert has been triggered.

Audit:

To verify Microsoft 365 Cloud App Security is enabled, use the Microsoft 365 SecureScore Portal:

1. Login to Microsoft 365 SecureScore portal (https://securescore.microsoft.com) using admin permissions (global admin or a custom admin role) for an Office 365 Enterprise, Microsoft 365 Business, or Office 365 Business Premium subscription.
2. Under `Improvement actions` select the link at the bottom to `View All`.
3. Next to `Applied filters:` clear the filter for `Not completed` by clicking the `X`.
4. Validate that the `Turn on Cloud App Security Console` action show that it has been `Completed`.

To verify Microsoft 365 Cloud App Security is enabled, use the Microsoft 365 SecureScore REST API:

```
GET https://graph.microsoft.com/beta/security/secureScores
```

ARCHIVE

Remediation:

To enable Microsoft 365 Cloud App Security, use the Microsoft 365 Admin Center:

1. Select `Security and Compliance`.
2. Select `Alerts`.
3. Select `Manage advanced alerts`.
4. Check `Turn on Microsoft 365 Cloud App Security`.
5. Click `Go to Microsoft 365 Cloud App Security`.

CIS Controls:

Version 7

6.2 Activate audit logging
Ensure that local logging has been enabled on all systems and networking devices.

16 Account Monitoring and Control
Account Monitoring and Control

ARCHIVE

5.14 (L1) Ensure the report of users who have had their email privileges restricted due to spamming is reviewed (Manual)

Profile Applicability:

- E3 Level 1

Description:

Review and unblock users who have been blocked for sending too many messages marked as spam/bulk.

Rationale:

Users who are found on the restricted users list have a high probability of having been compromised. Review of this list will allow an organization to remediate these user accounts, and then unblock them.

Audit:

To verify the report is being reviewed at least weekly, confirm that the necessary procedures are in place and being followed.

Remediation:

To review the report, use the Microsoft 365 Admin Center:

1. Select `Security and Compliance`.
2. Select `Threat Management` and `Review`.
3. Click `Restricted Users`.
4. Review alerts and take appropriate action (unblocking) after account has been remediated.

CIS Controls:

Version 7

6.2 <u>Activate audit logging</u>
Ensure that local logging has been enabled on all systems and networking devices.

ARCHIVE

5.15 (L1) Ensure Guest Users are reviewed at least biweekly (Manual)

Profile Applicability:

- E3 Level 1

Description:

Guest users can be set up for those users not in your tenant to still be granted access to resources. It is important to maintain visibility for what guest users are established in the tenant.

Rationale:

Periodic review of guest users ensures proper access to resources in your tenant.

Audit:

To verify the report is being reviewed at least biweekly, confirm that the necessary procedures are in place and being followed.

Remediation:

To view guest users, use the Microsoft 365 Admin Center:

1. Log in as an administrator
2. Navigate to the `Users` and `Guest Users`
3. Review the list of users

To verify Microsoft 365 audit log search is enabled, use the Microsoft Online PowerShell Module:

1. Run Microsoft Online PowerShell Module
2. Connect using `Connect-MSOnline`
3. Run the following PowerShell command:

```
Get-MsolUser -all |Where-Object {$_.UserType -ne "Member"} |Select-Object
UserPrincipalName, UserType, CreatedDate
```

4. Review the list of users

ARCHIVE

CIS Controls:

Version 7

6.2 Activate audit logging
Ensure that local logging has been enabled on all systems and networking devices.

16.6 Maintain an Inventory of Accounts
Maintain an inventory of all accounts organized by authentication system.

ARCHIVE

6 Storage

6.1 (L2) Ensure document sharing is being controlled by domains with whitelist or blacklist (Automated)

Profile Applicability:

- E3 Level 2

Description:

You should control sharing of documents to external domains by either blocking domains or only allowing sharing with specific named domains.

Rationale:

Attackers will often attempt to expose sensitive information to external entities through sharing, and restricting the domains that your users can share documents with will reduce that surface area.

Audit:

To verify document sharing settings, use the Microsoft 365 Admin Center:

1. Navigate to Microsoft 365 administration portal (`https://admin.microsoft.com`), Click on `Admin Centers` and then `SharePoint`.
2. Expand `Policies` then click `Sharing`.
3. Expand `More external sharing settings` and confirm that `Limit external sharing by domain` is checked.
4. Verify that an accurate list of allowed domains is listed.

To verify document sharing setting, you can also use SharePoint Online PowerShell:

1. Connect to SharePoint Online using Connect-SPOService
2. Run the following PowerShell command:

```
Get-SPOTenant | fl SharingDomainRestrictionMode,SharingAllowedDomainList
```

ARCHIVE

Remediation:

To configure document sharing restrictions, use the Microsoft 365 Admin Center:

1. Navigate to Microsoft 365 administration portal (`https://admin.microsoft.com`), Click on `Admin Centers` and then `SharePoint`.
2. Expand `Policies` then click `Sharing`.
3. Expand `More external sharing settings` and check `Limit external sharing by domain`.
4. Select `Add domains` to add a list of approved domains
5. Click `Save` at the bottom of the page.

To configure document sharing restrictions, you can also use SharePoint Online PowerShell:

1. Connect to SharePoint Online using Connect-SPOService
2. Run the following PowerShell command:

```
Set-SPOTenant -SharingDomainRestrictionMode AllowList -
SharingAllowedDomainList "domain1.com domain2.com"
```

Impact:

Enabling this feature will prevent users from sharing documents with domains outside of the organization unless allowed.

Default Value:

off

CIS Controls:

Version 7

13.4 Only Allow Access to Authorized Cloud Storage or Email Providers
Only allow access to authorized cloud storage or email providers.

14.6 Protect Information through Access Control Lists
Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.

ARCHIVE

6.2 (L2) Block OneDrive for Business sync from unmanaged devices (Automated)

Profile Applicability:

- E3 Level 2

Description:

You should prevent company data from OneDrive for Business from being synchronized to non-corporate managed devices.

Rationale:

Unmanaged devices pose a risk, since their security cannot be verified. Allowing users to sync data to these devices, takes that data out of the control of the organization. This increases the risk of the data either being intentionally or accidentally leaked.

Audit:

To verify sync settings on unmanaged devices, use the Microsoft 365 Admin Center:

1. Navigate to Microsoft 365 administration portal (`https://admin.microsoft.com`), Click on `All Admin Centers` and then `OneDrive`.
2. Click `Sync`.
3. Verify that `Allow syncing only on PCs joined to specific domains` is checked.
4. Verify that Domain GUIDs are listed in the box. Use the `Get-ADDomain` PowerShell command to obtain the GUID from each domain

To verify sync settings on unmanaged devices, you can also use SharePoint Online PowerShell:

1. Connect to SharePoint Online using Connect-SPOService
2. Run the following PowerShell command:

```
Get-SPOTenantSyncClientRestriction | fl
TenantRestrictionEnabled,AllowedDomainList
```

ARCHIVE

Remediation:

To block the sync client on unmanaged devices, use the Microsoft 365 Admin Center:

1. Navigate to Microsoft 365 administration portal (`https://admin.microsoft.com`), Click on `All Admin Centers` and then `OneDrive`.
2. Click `Sync`.
3. Ensure that `Allow syncing only on PCs joined to specific domains` is checked.
4. Use the `Get-ADDomain` PowerShell command to obtain the GUID from each domain in your environment and add them to the box below.
5. Click `Save`

To block the sync client on unmanaged devices, you can also use SharePoint Online PowerShell:

1. Connect to SharePoint Online using Connect-SPOService
2. Run the following PowerShell command and provide the DomainGuids from the Get-AADomain command:

```
Set-SPOTenantSyncClientRestriction  -Enable -DomainGuids "786548DD-877B-4760-A749-6B1EFBC1190A; 877564FF-877B-4760-A749-6B1EFBC1190A"
```

Impact:

Enabling this feature will prevent users from using the OneDrive for Business Sync client on devices that are not joined to the domains that were defined.

Default Value:

This feature is not enabled by default.

CIS Controls:

Version 7

13.4 <u>Only Allow Access to Authorized Cloud Storage or Email Providers</u>
Only allow access to authorized cloud storage or email providers.

14.6 <u>Protect Information through Access Control Lists</u>
Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.

ARCHIVE

6.3 (L1) Ensure expiration time for external sharing links is set (Automated)

Profile Applicability:

- E3 Level 1

Description:

You should restrict the length of time that anonymous access links are valid.

Rationale:

An attacker can compromise a user account for a short period of time, send anonymous sharing links to an external account, then take their time accessing the data. They can also compromise external accounts and steal the anonymous sharing links sent to those external entities well after the data has been shared. Restricting how long the links are valid can reduce the window of opportunity for attackers.

Audit:

To verify anonymous access links are correctly set to expire, use the Microsoft 365 Admin Center:

1. Select `Admin Centers` and `SharePoint`.
2. Expand `Polices` then click `Sharing`.
3. Click `These links must expire within this many days`.
4. Confirm the number of days is set to the desired value, such as `30`.

To verify anonymous links are correctly set to expire, you can also use SharePoint Online PowerShell:

1. Connect to SharePoint Online using Connect-SPOService
2. Run the following PowerShell command:

```
Get-SPOTenant | fl RequireAnonymousLinksExpireInDays
```

ARCHIVE

Remediation:

To set expiration for anonymous access links, use the Microsoft 365 Admin Center

1. Select `Admin Centers` and `SharePoint`.
2. Expand `Polices` then click `Sharing`.
3. Check `These links must expire within this many days`.
4. Set to the desired number of days, such as `30`.
5. Click `OK`.

To set expiration for anonymous access links, you can also use SharePoint Online PowerShell:

1. Connect to SharePoint Online using Connect-SPOService
2. Run the following PowerShell command:

```
set-SPOTenant -RequireAnonymousLinksExpireInDays 30
```

Impact:

Enabling this feature will ensure that link expire within the defined number of days. This will have an affect on links that were previously not set with an expiration.

Default Value:

Anonymous Sharing - `On`

Sharing Links Expiration - `Off`

References:

1. https://docs.microsoft.com/en-us/sharepoint/turn-external-sharing-on-or-off

ARCHIVE

Notes:

Setting links to expire in X number of days only applies in the most permissive sharing mode which is the default setting. Organizations should decide on an organizational level whether to allow external sharing and to what level.

CIS Controls:

Version 7

13.2 Remove Sensitive Data or Systems Not Regularly Accessed by Organization
Remove sensitive data or systems not regularly accessed by the organization from the network. These systems shall only be used as stand alone systems (disconnected from the network) by the business unit needing to occasionally use the system or completely virtualized and powered off until needed.

16.10 Ensure All Accounts Have An Expiration Date
Ensure that all accounts have an expiration date that is monitored and enforced.

ARCHIVE

6.4 (L2) Ensure external storage providers available in Outlook on the Web are restricted (Automated)

Profile Applicability:

- E3 Level 2

Description:

You should restrict storage providers that are integrated with Outlook on the Web.

Rationale:

By default additional storage providers are allowed in Outlook on the Web (such as Box, Dropbox, Facebook, Google Drive, OneDrive Personal, etc.). This could lead to information leakage and additional risk of infection from organizational non-trusted storage providers. Restricting this will inherently reduce risk as it will narrow opportunities for infection and data leakage.

Audit:

To verify external storage providers are disabled, use the Exchange Online PowerShell Module:

1. Connect to Exchange Online using `Connect-EXOPSSession`.
2. Run the following Powershell command:

```
Get-OwaMailboxPolicy | Format-Table Name, AdditionalStorageProvidersAvailable
```

3. Verify that the value returned is `False`.

ARCHIVE

Remediation:

To disable external storage providers, use the Exchange Online PowerShell Module:

1. Connect to Exchange Online using `Connect-EXOPSSession`.
2. Run the following Powershell command:

```
Set-OwaMailboxPolicy -Identity OwaMailboxPolicy-Default -
AdditionalStorageProvidersAvailable $false
```

3. Run the following Powershell command to verify that the value is now `False`:

```
Get-OwaMailboxPolicy | Format-Table Name, AdditionalStorageProvidersAvailable
```

Impact:

Impact associated with this change is highly dependent upon current practices in the tenant. If users do not use other storage providers, then minimal impact is likely. However, if users do regularly utilize providers outside of the tenant this will affect their ability to continue to do so.

Default Value:

Additional Storage Providers - True

References:

1. https://docs.microsoft.com/en-us/powershell/module/exchange/client-access/set-owamailboxpolicy?view=exchange-ps

CIS Controls:

Version 7

13.1 Maintain an Inventory Sensitive Information
Maintain an inventory of all sensitive information stored, processed, or transmitted by the organization's technology systems, including those located onsite or at a remote service provider.

13.4 Only Allow Access to Authorized Cloud Storage or Email Providers
Only allow access to authorized cloud storage or email providers.

ARCHIVE

7 Mobile Device Management

7.1 (L1) Ensure mobile device management polices are set to require advanced security configurations to protect from basic internet attacks (Manual)

Profile Applicability:

- E3 Level 1

Description:

You should configure your mobile device management policies to require advanced security configurations. If you do not require this, users will be able to connect from devices that are vulnerable to basic internet attacks, leading to potential breaches of accounts and data.

Rationale:

Managing mobile devices in your organization, helps provide a basic level of security to protect against attacks from these platforms. For example ensure that the device is up to date on patches or is not rooted. These configurations open those devices to vulnerabilities that are addressed in patched versions of the mobile OS.

Audit:

To verify mobile device management profiles, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Configuration profiles`
3. Ensure that profiles exist and are assigned for relevant mobile device types

ARCHIVE

Remediation:

To set mobile device management profiles, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Configuration profiles`
3. Select `Create profile` to create a new profile. Select the appropriate Platform and settings from the configuration screens.

Impact:

The impact associated with this change is dependent upon the settings specified in the mobile device configuration profile.

CIS Controls:

Version 7

5.1 Establish Secure Configurations

Maintain documented, standard security configuration standards for all authorized operating systems and software.

ARCHIVE

7.2 (L1) Ensure that mobile device password reuse is prohibited (Manual)

Profile Applicability:

- E3 Level 1

Description:

You should not allow your users to reuse the same password on their mobile devices.

Rationale:

Devices without this protection are vulnerable to being accessed by attackers who can then steal account credentials, data, or install malware on the device. Choosing unique and unused passwords every time a password changes on mobile devices lessens the likelihood that the password can be guessed by an attacker.

Audit:

To verify mobile device management profiles, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Configuration profiles`
3. Review the list of profiles. Ensure that a profile exists for each `Platform`.
4. Review the `Device restrictions` section under `Password` and verify `Prevent reuse of previous passwords` is set to `5`.

Remediation:

To set mobile device management profiles, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Configuration profiles`
3. Select `Create profile`
4. Set a `Name` for the policy, choose the appropriate `Platform`and select `Device restrictions`
5. In the `Password` section, ensure that `Prevent reuse of previous passwords` is set to `5`.

ARCHIVE

Impact:

This change will have a moderate user impact

Default Value:

Password reuse is not enforced by default.

CIS Controls:

Version 7

4.4 Use Unique Passwords
Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.

5.1 Establish Secure Configurations
Maintain documented, standard security configuration standards for all authorized operating systems and software.

ARCHIVE

7.3 (L1) Ensure that mobile devices are set to never expire passwords (Manual)

Profile Applicability:

- E3 Level 1

Description:

Ensure that users passwords on their mobile devices, never expire.

Rationale:

While this is not the most intuitive recommendation, research has found that when periodic password resets are enforced, passwords become weaker as users tend to pick something weaker and then use a pattern of it for rotation. If a user creates a strong password: long, complex and without any pragmatic words present, it should remain just as strong is 60 days as it is today. It is Microsoft's official security position to not expire passwords periodically without a specific reason.

Audit:

To verify mobile device management profile, use the Microsoft 365 Admin Center:

1. Select `Device Management` under `Admin Centers`.
2. Select `Devices`, then `Configuration profiles`
3. Review the list of profiles. Ensure that a profile exists for each `Platform`.
4. Review the `Device restrictions` section and under `Password` verify that passwords are not configured to expire.

Remediation:

To set mobile device management profiles, use the Microsoft 365 Admin Center:

1. Select `Device Management` under `Admin Centers`.
2. Select `Devices`, then `Configuration profiles`
3. Review the list of profiles.
4. From there, go to the device policies page to remove any device security policies that expire passwords.

ARCHIVE

Impact:

This setting should not cause a noticeable impact to users

Default Value:

Password changes are not required by default

CIS Controls:

Version 7

5.1 Establish Secure Configurations
Maintain documented, standard security configuration standards for all authorized operating systems and software.

16 Account Monitoring and Control
Account Monitoring and Control

ARCHIVE

7.4 (L1) Ensure that users cannot connect from devices that are jail broken or rooted (Manual)

Profile Applicability:

- E3 Level 1

Description:

You should not allow your users to use to connect with mobile devices that have been jail broken or rooted.

Rationale:

These devices have had basic protections disabled to run software that is often malicious and could very easily lead to an account or data breach.

Audit:

To verify mobile device management policies, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Configuration profiles`
3. Review the list of profiles. Ensure that a profile exists for each `Platform`.
4. Review the `Device Health` section under `Settings` and verify `Jailbroken devices` is set to `Block`.

Remediation:

To set mobile device management policies, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Configuration profiles`
3. Select `Create Policy`
4. Set a `Name` for the policy, choose the appropriate `Platform`
5. Under `Settings` and `Device Health` ensure that `Jailbroken devices` is set to `Block`.

ARCHIVE

Impact:

Impact should be minimal however, in the event that a device is Jailbroken or running a developer build of a mobile Operating System it will be blocked from connecting.

CIS Controls:

Version 7

18.3 Verify That Acquired Software is Still Supported

Verify that the version of all software acquired from outside your organization is still supported by the developer or appropriately hardened based on developer security recommendations.

18.4 Only Use Up-to-date And Trusted Third-Party Components

Only use up-to-date and trusted third-party components for the software developed by the organization.

ARCHIVE

7.5 (L2) Ensure mobile devices are set to wipe on multiple sign-in failures to prevent brute force compromise (Manual)

Profile Applicability:

- E3 Level 2

Description:

Require mobile devices to wipe on multiple sign-in failures

Rationale:

Devices without this protection are vulnerable to being accessed physically by attackers who can then steal account credentials, data, or install malware on the device.

Audit:

To verify mobile device management profiles, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Configuration profiles`
3. Review the list of profiles. Ensure that a profile exists for each `Platform`.
4. Review the `Password` section under `Device restrictions` and verify `Number of sign-in failures before wiping device` is set to `10`.

Remediation:

To set mobile device management profiles, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Configuration profiles`
3. Select `Create profile`
4. Set a `Name` for the policy, choose the appropriate `Platform` and select `Device restrictions`
5. In the `Password` section, ensure that `Number of sign-in failures before wiping device` is set to `10`.

ARCHIVE

Impact:

This setting has no impact, unless a user mistypes their password multiple times and causes their device to wipe. In that case, it will have a high user impact.

Default Value:

The default is to not wipe the device on multiple failed attempts.

CIS Controls:

Version 7

5.1 Establish Secure Configurations
Maintain documented, standard security configuration standards for all authorized operating systems and software.

16.7 Establish Process for Revoking Access
Establish and follow an automated process for revoking system access by disabling accounts immediately upon termination or change of responsibilities of an employee or contractor . Disabling these accounts, instead of deleting accounts, allows preservation of audit trails.

ARCHIVE

7.6 (L1) Ensure that mobile devices require a complex password to prevent brute force attacks (Manual)

Profile Applicability:

- E3 Level 1

Description:

You should require your users to use a complex password with a minimum password length of at least six characters to unlock their mobile devices.

Rationale:

Devices without this protection are vulnerable to being accessed physically by attackers who can then steal account credentials, data, or install malware on the device.

Audit:

To verify mobile device management profiles, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Configuration profiles`
3. Review the list of profiles. Ensure that a profile exists for each `Platform`.
4. Review the `Password` section under `Device restrictions` and verify `Minimum password length` is set to `6`.

Remediation:

To set mobile device management profiles, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Configuration profiles`
3. Select `Create profile`
4. Set a `Name` for the policy, choose the appropriate `Platform` and select `Device restrictions`
5. In the `Password` section, ensure that `Minimum password length` is set to `6`.

ARCHIVE

Impact:

This change has a moderate user impact

Default Value:

Minimum password lengths are not enforced by default

CIS Controls:

Version 7

4.4 Use Unique Passwords

Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.

ARCHIVE

7.7 (L1) Ensure that settings are enable to lock devices after a period of inactivity to prevent unauthorized access (Manual)

Profile Applicability:

- E3 Level 1

Description:

You should require your users to configure their mobile devices to lock on inactivity.

Rationale:

Attackers can steal unlocked devices and access data and account information.

Audit:

To verify mobile device management profiles, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Configuration profiles`
3. Review the list of profiles. Ensure that a profile exists for each `Platform`.
4. Review the `Password` section under `Device restrictions`
5. Verify `Maximum minutes of inactivity until screen lock` is set to `5` and `Maximum minutes after screen lock before password is required` is set to `Immediately`

Remediation:

To set mobile device management policies, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Configuration profiles`
3. Select `Create profile`
4. Set a `Name` for the policy, choose the appropriate `Platform` and select `Device restrictions`
5. In the `Password` section, ensure that `Maximum minutes of inactivity until screen lock` is set to `5` and `Maximum minutes after screen lock before password is required` is set to `Immediately`

ARCHIVE

Impact:

This setting has a low impact on users.

Default Value:

Screen locking is not enabled by default.

CIS Controls:

Version 7

5 Secure Configuration for Hardware and Software on Mobile Devices, Laptops, Workstations and Servers

Secure Configuration for Hardware and Software on Mobile Devices, Laptops, Workstations and Servers

16.11 Lock Workstation Sessions After Inactivity

Automatically lock workstation sessions after a standard period of inactivity.

ARCHIVE

7.8 (L1) Ensure that mobile device encryption is enabled to prevent unauthorized access to mobile data (Manual)

Profile Applicability:

- E3 Level 1

Description:

You should require your users to use encryption on their mobile devices.

Rationale:

Unencrypted devices can be stolen and their data extracted by an attacker very easily.

Audit:

To verify mobile device management profiles, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Configuration profiles`
3. Review the list of profiles. Ensure that a profile exists for `Android`.
4. Review the `Password` section under `Device restrictions` and verify `Encryption` is set to `Require`.

Remediation:

To set mobile device management profiles, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Configuration profiles`
3. Select `Create profile`
4. Set a `Name` for the policy, choose `Android` as the `Platform` and select `Device restrictions`
5. In the `Password` section, ensure that `Encryption` is set to `Require`.

ARCHIVE

Impact:

This setting should have no user impact, provided the device supports the feature.

Default Value:

Device encryption is not required by the O365 platform by default, although some mobile platforms are encrypted by default.

CIS Controls:

Version 7

5 Secure Configuration for Hardware and Software on Mobile Devices, Laptops, Workstations and Servers

Secure Configuration for Hardware and Software on Mobile Devices, Laptops, Workstations and Servers

13.6 Encrypt the Hard Drive of All Mobile Devices.

Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.

ARCHIVE

7.9 (L1) Ensure that mobile devices require complex passwords (Type = Alphanumeric) (Manual)

Profile Applicability:

- E3 Level 1

Description:

You should require your users to use a complex password with a at least two character sets (letters and numbers, for example) to unlock their mobile devices.

Rationale:

Devices without this protection are vulnerable to being accessed physically by attackers who can then steal account credentials, data, or install malware on the device.

Audit:

To verify mobile device management profiles, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Configuration profiles`
3. Review the list of profiles. Ensure that a profile exists for each `Platform`.
4. Review the `Password` section under `Device restrictions` and verify `Required password type` is set to `Alphanumeric`.

Remediation:

To set mobile device management profiles, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Configuration profiles`
3. Select `Create profile`
4. Set a `Name` for the policy, choose the appropriate `Platform` and select `Device restrictions`
5. In the `Password` section, ensure that `Required password type` is set to `Alphanumeric`.

ARCHIVE

Impact:

This setting will have a moderate user impact

Default Value:

This setting is not enabled by default.

CIS Controls:

Version 7

4.4 Use Unique Passwords

Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.

5 Secure Configuration for Hardware and Software on Mobile Devices, Laptops, Workstations and Servers

Secure Configuration for Hardware and Software on Mobile Devices, Laptops, Workstations and Servers

ARCHIVE

7.10 (L1) Ensure that mobile devices require complex passwords (Simple Passwords = Blocked) (Manual)

Profile Applicability:

- E3 Level 1

Description:

You should require your users to use a complex password to unlock their mobile devices.

Rationale:

Devices without this protection are vulnerable to being accessed physically by attackers who can then steal account credentials, data, or install malware on the device.

Audit:

To verify mobile device management profiles, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Configuration profiles`
3. Review the list of profiles. Ensure that a profile exists for each `Platform`.
4. Review the `Password` section under `Device restrictions` and verify `Simple Passwords` is set to `Blocked`.

Remediation:

To set mobile device management profiles, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Configuration profiles`
3. Select `Create profile`
4. Set a `Name` for the policy, choose the appropriate `Platform` and select `Device restrictions`
5. In the `Password` section, ensure that `Simple Passwords` is set to `Blocked`.

ARCHIVE

Impact:

This has a moderate impact on users

Default Value:

This setting is not enabled by default

CIS Controls:

Version 7

4.4 Use Unique Passwords
Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.

5.1 Establish Secure Configurations
Maintain documented, standard security configuration standards for all authorized operating systems and software.

ARCHIVE

7.11 (L1) Ensure that devices connecting have AV and a local firewall enabled (Manual)

Profile Applicability:

- E3 Level 1

Description:

You should configure your mobile device management policies to require the PC to have anti-virus and have a firewall enabled.

Rationale:

If you do not require this, users will be able to connect from devices that are vulnerable to basic internet attacks, leading to potential breaches of accounts and data.

Audit:

To verify mobile device management policies, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Compliance policies`
3. Review the list of policies. Ensure that a policy exists for each `Platform`.
4. Review the `Properties` section of each policy. Under `Settings` and `System Security` verify the value for `Firewall`, `Antivirus`, and `Antispyware` are all set to `Require`.

Remediation:

To set mobile device management policies, use the Microsoft 365 Admin Center:

1. Under `Admin Centers` select `Endpoint Management`.
2. Select `Devices` and then select `Compliance policies`
3. Select `Create Policy`
4. Set a `Name` for the policy, choose the appropriate PC `Platform`
5. Select `System Security` under `Settings`.
6. Under `Device Security` set the values for `Firewall`, `Antivirus`, and `Antispyware` all to `Require`.

ARCHIVE

Impact:

Impact should be minimal however, in the event that a device is not running appropriate protection it will be blocked from connecting.

CIS Controls:

Version 7

8.1 Utilize Centrally Managed Anti-malware Software
Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.

8.2 Ensure Anti-Malware Software and Signatures are Updated
Ensure that the organization's anti-malware software updates its scanning engine and signature database on a regular basis.

9.4 Apply Host-based Firewalls or Port Filtering
Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.

ARCHIVE

7.12 (L2) Ensure mobile device management policies are required for email profiles (Manual)

Profile Applicability:

- E3 Level 2

Description:

You should configure your mobile device management policies to require the policy to manage the email profile of the user.

Rationale:

If you do not require this, users will be able to setup and configure email accounts without the protections of the mobile device management policy, leading to potential breaches of accounts and data.

Audit:

To verify mobile device management policies, use the Microsoft 365 Admin Center:

1. Select `Device Management` under `Admin Centers`.
2. Select `Device compliance` and then select `Policies`
3. Review the list of profiles. Ensure that a profile exists for each `Platform`.
4. Review the `Email` section under `Settings` and verify `Require mobile devices to have a managed email profile` is set to `Require`.

Remediation:

To set mobile device management policies, use the Microsoft 365 Admin Center:

1. Select `Device Management` under `Admin Centers`.
2. Select `Device compliance` and then select `Policies`
3. Select `Create Policy`
4. Set a `Name` for the policy, choose the appropriate `Platform`
5. Under `Settings` and `Email` ensure that `Require mobile devices to have a managed email profile` is set to `Require`.

ARCHIVE

Impact:

This setting will have a moderate impact on users

Default Value:

This setting is not enabled by default

CIS Controls:

Version 7

7 Email and Web Browser Protections
Email and Web Browser Protections

7.1 Ensure Use of Only Fully Supported Browsers and Email Clients
Ensure that only fully supported web browsers and email clients are allowed to execute in the organization, ideally only using the latest version of the browsers and email clients provided by the vendor.

ARCHIVE

7.13 (L1) Ensure mobile devices require the use of a password (Manual)

Profile Applicability:

- E3 Level 1

Description:

You should require your users to use a password to unlock their mobile devices.

Rationale:

Devices without this protection are vulnerable to being accessed physically by attackers who can then steal account credentials, data, or install malware on the device.

Audit:

To verify mobile device management profiles, use the Microsoft 365 Admin Center:

1. Select `Device Management` under `Admin Centers`.
2. Select `Device configuration` and then select `Profiles`
3. Review the list of profiles. Ensure that a profile exists for each `Platform`.
4. Review the `Password` section under `Device restrictions` and verify `Password` is set to `Require`.

Remediation:

To set mobile device management profiles, use the Microsoft 365 Admin Center:

1. Select `Device Management` under `Admin Centers`.
2. Select `Device configuration` and then select `Profiles`
3. Select `Create profile`
4. Set a `Name` for the policy, choose the appropriate `Platform` and select `Device restrictions`
5. In the `Password` section, ensure that `Password` is set to `Require`.

ARCHIVE

Impact:

This change will require users to provide a password to unlock their mobile device after the timeout period expires

Default Value:

This setting is not enabled by default.

CIS Controls:

Version 7

4.4 Use Unique Passwords
Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.

5.1 Establish Secure Configurations
Maintain documented, standard security configuration standards for all authorized operating systems and software.

16.11 Lock Workstation Sessions After Inactivity
Automatically lock workstation sessions after a standard period of inactivity.

ARCHIVE

Appendix: Summary Table

Control		Set Correctly	
		Yes	No
1	**Account / Authentication**		
1.1	**Azure Active Directory**		
1.1.1	(L1) Ensure multifactor authentication is enabled for all users in administrative roles (Automated)	☐	☐
1.1.2	(L2) Ensure multifactor authentication is enabled for all users in all roles (Manual)	☐	☐
1.1.3	(L1) Ensure that between two and four global admins are designated (Automated)	☐	☐
1.1.4	(L1) Ensure self-service password reset is enabled (Automated)	☐	☐
1.1.5	(L1) Ensure that password protection is enabled for Active Directory (Manual)	☐	☐
1.1.6	(L1) Enable Conditional Access policies to block legacy authentication (Automated)	☐	☐
1.1.7	(L1) Ensure that password hash sync is enabled for resiliency and leaked credential detection (Manual)	☐	☐
1.1.8	(L1) Enabled Identity Protection to identify anomalous logon behavior (Manual)	☐	☐
1.1.9	(L2) Enable Azure AD Identity Protection sign-in risk policies (Manual)	☐	☐
1.1.10	(L2) Enable Azure AD Identity Protection user risk policies (Manual)	☐	☐
1.1.11	(L2) Use Just In Time privileged access to Office 365 roles (Manual)	☐	☐
1.1.12	(L1) Ensure Security Defaults is disabled on Azure Active Directory (Manual)	☐	☐
1.2	(L1) Ensure modern authentication for Exchange Online is enabled (Automated)	☐	☐
1.3	(L1) Ensure modern authentication for Skype for Business Online is enabled (Automated)	☐	☐
1.4	(L1) Ensure modern authentication for SharePoint applications is required (Automated)	☐	☐
1.5	(L1) Ensure that Office 365 Passwords Are Not Set to Expire (Automated)	☐	☐
2	**Application Permissions**		
2.1	(L2) Ensure third party integrated applications are not allowed (Manual)	☐	☐

ARCHIVE

Control		Set Correctly	
		Yes	No
2.2	(L2) Ensure calendar details sharing with external users is disabled (Automated)	☐	☐
2.3	(L2) Ensure O365 ATP SafeLinks for Office Applications is Enabled (Automated)	☐	☐
2.4	(L2) Ensure Office 365 ATP for SharePoint, OneDrive, and Microsoft Teams is Enabled (Automated)	☐	☐
2.5	(L2) Ensure Office 365 SharePoint infected files are disallowed for download (Automated)	☐	☐
2.6	(L2) Ensure user consent to apps accessing company data on their behalf is not allowed (Automated)	☐	☐
2.7	(L2) Ensure the admin consent workflow is enabled (Automated)	☐	☐
2.8	(L2) - Ensure users installing Outlook add-ins is not allowed (Automated)	☐	☐
2.9	(L1) - Ensure users installing Word, Excel, and PowerPoint add-ins is not allowed (Manual)	☐	☐
3	**Data Management**		
3.1	(L2) Ensure the customer lockbox feature is enabled (Automated)	☐	☐
3.2	(L2) Ensure SharePoint Online data classification policies are set up and used (Manual)	☐	☐
3.3	(L2) Ensure external domains are not allowed in Skype or Teams (Manual)	☐	☐
3.4	(L1) Ensure DLP policies are enabled (Automated)	☐	☐
3.5	(L1) Ensure DLP policies are enabled for Microsoft Teams (Manual)	☐	☐
3.6	(L2) Ensure that external users cannot share files, folders, and sites they do not own (Automated)	☐	☐
3.7	(L2) Ensure external file sharing in Teams is enabled for only approved cloud storage services (Manual)	☐	☐
4	**Email Security / Exchange Online**		
4.1	(L1) Ensure the Common Attachment Types Filter is enabled (Automated)	☐	☐
4.2	(L1) Ensure Exchange Online Spam Policies are set correctly (Automated)	☐	☐
4.3	(L1) Ensure mail transport rules do not forward email to external domains (Automated)	☐	☐
4.4	(L2) Ensure automatic forwarding options are disabled (Automated)	☐	☐
4.5	(L1) Ensure mail transport rules do not whitelist specific domains (Automated)	☐	☐

ARCHIVE

Control		Set Correctly	
		Yes	No
4.6	(L2) Ensure the Client Rules Forwarding Block is enabled (Automated)	☐	☐
4.7	(L2) Ensure the Advanced Threat Protection Safe Links policy is enabled (Automated)	☐	☐
4.8	(L2) Ensure the Advanced Threat Protection Safe Attachments policy is enabled (Automated)	☐	☐
4.9	(L2) Ensure basic authentication for Exchange Online is disabled (Automated)	☐	☐
4.10	(L1) Ensure that an anti-phishing policy has been created (Automated)	☐	☐
4.11	(L1) Ensure that DKIM is enabled for all Exchange Online Domains (Automated)	☐	☐
4.12	(L1) Ensure that SPF records are published for all Exchange Domains (Manual)	☐	☐
4.13	(L1) Ensure DMARC Records for all Exchange Online domains are published (Manual)	☐	☐
4.14	(L1) Ensure notifications for internal users sending malware is Enabled (Automated)	☐	☐
4.15	(L2) Ensure MailTips are enabled for end users (Automated)	☐	☐
4.16	(L2) Ensure that LinkedIn contact synchronization is disabled. (Automated)	☐	☐
4.17	(L2) Ensure that Facebook contact synchronization is disabled. (Automated)	☐	☐
5	**Auditing**		
5.1	(L1) Ensure Microsoft 365 audit log search is Enabled (Automated)	☐	☐
5.2	(L1) Ensure mailbox auditing for all users is Enabled (Automated)	☐	☐
5.3	(L1) Ensure the Azure AD 'Risky sign-ins' report is reviewed at least weekly (Manual)	☐	☐
5.4	(L2) Ensure the Application Usage report is reviewed at least weekly (Manual)	☐	☐
5.5	(L1) Ensure the self-service password reset activity report is reviewed at least weekly (Manual)	☐	☐
5.6	(L1) Ensure user role group changes are reviewed at least weekly (Manual)	☐	☐
5.7	(L1) Ensure mail forwarding rules are reviewed at least weekly (Manual)	☐	☐
5.8	(L1) Ensure the Mailbox Access by Non-Owners Report is reviewed at least biweekly (Manual)	☐	☐

ARCHIVE

Control		Set Correctly	
		Yes	No
5.9	(L1) Ensure the Malware Detections report is reviewed at least weekly (Manual)	☐	☐
5.10	(L1) Ensure the Account Provisioning Activity report is reviewed at least weekly (Manual)	☐	☐
5.11	(L1) Ensure non-global administrator role group assignments are reviewed at least weekly (Manual)	☐	☐
5.12	(L1) Ensure the spoofed domains report is review weekly (Manual)	☐	☐
5.13	(L2) Ensure Microsoft 365 Cloud App Security is Enabled (Manual)	☐	☐
5.14	(L1) Ensure the report of users who have had their email privileges restricted due to spamming is reviewed (Manual)	☐	☐
5.15	(L1) Ensure Guest Users are reviewed at least biweekly (Manual)	☐	☐
6	**Storage**		
6.1	(L2) Ensure document sharing is being controlled by domains with whitelist or blacklist (Automated)	☐	☐
6.2	(L2) Block OneDrive for Business sync from unmanaged devices (Automated)	☐	☐
6.3	(L1) Ensure expiration time for external sharing links is set (Automated)	☐	☐
6.4	(L2) Ensure external storage providers available in Outlook on the Web are restricted (Automated)	☐	☐
7	**Mobile Device Management**		
7.1	(L1) Ensure mobile device management polices are set to require advanced security configurations to protect from basic internet attacks (Manual)	☐	☐
7.2	(L1) Ensure that mobile device password reuse is prohibited (Manual)	☐	☐
7.3	(L1) Ensure that mobile devices are set to never expire passwords (Manual)	☐	☐
7.4	(L1) Ensure that users cannot connect from devices that are jail broken or rooted (Manual)	☐	☐
7.5	(L2) Ensure mobile devices are set to wipe on multiple sign-in failures to prevent brute force compromise (Manual)	☐	☐
7.6	(L1) Ensure that mobile devices require a complex password to prevent brute force attacks (Manual)	☐	☐
7.7	(L1) Ensure that settings are enable to lock devices after a period of inactivity to prevent unauthorized access (Manual)	☐	☐

ARCHIVE

Control		Set Correctly	
		Yes	No
7.8	(L1) Ensure that mobile device encryption is enabled to prevent unauthorized access to mobile data (Manual)	☐	☐
7.9	(L1) Ensure that mobile devices require complex passwords (Type = Alphanumeric) (Manual)	☐	☐
7.10	(L1) Ensure that mobile devices require complex passwords (Simple Passwords = Blocked) (Manual)	☐	☐
7.11	(L1) Ensure that devices connecting have AV and a local firewall enabled (Manual)	☐	☐
7.12	(L2) Ensure mobile device management policies are required for email profiles (Manual)	☐	☐
7.13	(L1) Ensure mobile devices require the use of a password (Manual)	☐	☐

ARCHIVE

Appendix: Change History

Date	Version	Changes for this version
Dec 16, 2019	1.1.0	ADD - 1.1.9: (L2) Enable Azure AD Identi... (Ticket 9034)
Dec 16, 2019	1.1.0	ADD - 1.1.8: (L1) Enabled Identity Prote... (Ticket 9033)
Dec 16, 2019	1.1.0	ADD - 1.1.7: (L1) Ensure that password h... (Ticket 9002)
Dec 16, 2019	1.1.0	ADD - 1.1.6: (L1) Enable Conditional Acc... (Ticket 9001)
Dec 16, 2019	1.1.0	ADD - 1.1.5: (L1) Ensure that password p... (Ticket 8933)
Dec 16, 2019	1.1.0	UPDATE - 4.7: (L2) Ensure the Advanced T... (Ticket 8891)
Dec 16, 2019	1.1.0	UPDATE - 5.1: (L1) Ensure Microsoft 365... (Ticket 8892)
Dec 16, 2019	1.1.0	ADD - 4.14: (L2) Ensure MailTips are ena... (Ticket 8915)
Dec 16, 2019	1.1.0	ADD - 5.15: (L1) Ensure Guest Users are... (Ticket 8941)
Dec 16, 2019	1.1.0	UPDATE - 4.6: (L2) Ensure the Advanced T... (Ticket 8890)
Dec 16, 2019	1.1.0	UPDATE - 4.11: (L1) Ensure that SPF reco... (Ticket 8940)
Dec 16, 2019	1.1.0	UPDATE - 3.1: (L2) Ensure the customer l... (Ticket 8939)
Dec 16, 2019	1.1.0	UPDATE - 2.3 (L2) Ensure O365 ATP SafeLi... (Ticket 9490)
Dec 16, 2019	1.1.0	UPDATE - 5.1: (L1) Ensure Microsoft 365... (Ticket 9631)
Dec 16, 2019	1.1.0	UPDATE - 5.6: (L1) Ensure user role grou... (Ticket 8626)
Dec 16, 2019	1.1.0	UPDATE - 5.10: (L1) Ensure the Account P... (Ticket 8627)
Dec 16, 2019	1.1.0	UPDATE - 1.1.4: (L1) Ensure self-service... (Ticket 9038)
Dec 16, 2019	1.1.0	UPDATE - 1.1.3: (L1) Ensure that between... (Ticket 9037)
Dec 16, 2019	1.1.0	UPDATE - 7.3: (L1) Ensure that mobile de... (Ticket 9181)
Dec 16, 2019	1.1.0	ADD - 6.2: (L2) Block OneDrive for Busin... (Ticket 9039)

Date	Version	Changes for this version
Dec 16, 2019	1.1.0	ADD - 3.5: (L1) Ensure DLP policies are... (Ticket 9141)
Dec 16, 2019	1.1.0	ADD - 1.1.11: (L2) Use Just In Time priv... (Ticket 9143)
Dec 16, 2019	1.1.0	ADD - 1.1.10: (L2) Enable Azure AD Ident... (Ticket 9036)
Dec 16, 2019	1.1.0	ADD - 1.1: Azure Active Directory (Ticket 8414)
Dec 16, 2019	1.1.0	UPDATE - 2.1 & 7.x: Scored (Automatic) R... (Ticket 9632)
Feb 24, 2020	1.2.0	UPDATE - 3.1 (L2) Ensure the customer lockbox feature is enabled - Powershell Instructions (Ticket 9539)
Feb 24, 2020	1.2.0	UPDATE - 6.2 (L2) Block OneDrive for Business sync from unmanaged devices (Ticket 10104)
Feb 24, 2020	1.2.0	UPDATE - 7.9 (L1) Ensure that mobile devices require complex passwords (Type = Alphanumeric) (Ticket 10280)
Feb 24, 2020	1.2.0	UPDATE - 7.10 (L1) Ensure that mobile devices require complex passwords (Simple Passwords = Blocked) (Ticket 9903)
Mar 6, 2020	1.2.0	UPDATE - 3.5 (L1) Ensure DLP policies are enabled for Microsoft Teams (Ticket 10125)
Mar 31, 2020	1.2.0	Update - 'Services and add-ins' is 'Settings' (Ticket 10474)
Mar 31, 2020	1.2.0	Update - Conditional Access is now nested under Security (Ticket 10420)
Mar 31, 2020	1.2.0	Update - Remediation Procedure 1.1.3 - Add user(s) w/role(s) via Powershell (Ticket 10492)
Mar 31, 2020	1.2.0	Update - 1.1.4 - UI Changes for location of self service password reset (Ticket 10527)
Mar 31, 2020	1.2.0	Update - Remediation Procedure 4.3 - Remove external forwarders via Powershell (Ticket 10493)
Mar 31, 2020	1.2.0	Update - Remediation Procedure - Connect-MSOnline (Ticket 10429)
Apr 8, 2020	1.2.0	UPDATE - Outbound Spam - New Location (Ticket 10427)

Date	Version	Changes for this version
Apr 9, 2020	1.2.0	ADD - Ensure that Outlook Contacts synchronization of LinkedIn contacts is disabled. (Ticket 8967)
Apr 9, 2020	1.2.0	ADD - Ensure that Outlook Contacts synchronization of Facebook contacts is disabled. (Ticket 8966)
Apr 10, 2020	1.2.0	ADD - 1.1.14 (L1) Ensure Security Defaults is enabled on Azure Active Directory (Ticket 10418)
Apr 15, 2020	1.2.0	DELETE - 4.14 and 4.15 are duplicates, please remove one. (Ticket 10618)
Apr 15, 2020	1.2.0	Update - 1.5 (L1) Ensure that Office 365 Passwords Are Not Set to Expire - Password expiration policy options (Ticket 10456)
Apr 30, 2020	1.2.0	ADD - External Storage Providers default available Teams (Ticket 8994)
May 6, 2020	1.2.0	UPDATE - (L1) Ensure DLP policies are enabled - SecureScore Portal items missing (Ticket 10535)
May 6, 2020	1.2.0	UPDATE - Expiration time for external sharing clarification (Ticket 7523)
May 7, 2020	1.2.0	UPDATE - (L1) Ensure that Office 365 Passwords Are Not Set to Expire - Does Azure AD Password Protection also help here? (Ticket 10430)
May 8, 2020	1.2.0	UPDATE - (L1) Ensure Security defaults is enabled on Azure Active Directory - should read DISABLED (Ticket 10700)
May 12, 2020	1.2.0	ADD - (L2) External Storage Providers available in Outlook on the Web by default (New Recommendation) (Ticket 8961)
May 15, 2020	1.2.0	ADD - Disable Auto-forwarding rules (Ticket 10550)
May 21, 2020	1.2.0	REMOVE -1.1.13 (L2) Ensure that AD Application client secrets are rotated before they expires (Ticket 10417)
Jun 11, 2020	1.2.0	UPDATE - Update Control Mappings (Ticket 10917)

Date	Version	Changes for this version
Jun 12, 2020	1.2.0	UPDATE - AllowBasicAuthRest is no longer availiable (Ticket 10428)
Jun 12, 2020	1.2.0	UPDATE - 4.9 - Set-AuthenticationPolicy does not have - AllowBasicAuthRest (Ticket 9499)
Jun 15, 2020	1.2.0	UPDATE - 4.9 Remediation does not handle case where "Block Basic Auth" already exists (Ticket 9500)
Jun 15, 2020	1.2.0	UPDATE - 4.9 - Make audit check more prescriptive (Ticket 9559)
Jun 15, 2020	1.2.0	UPDATE - 3.6 - Restrictions to Guest Collaboration (Ticket 8971)
Jun 18, 2020	1.2.0	UPDATE - 3.4 (L1) - Ensure DLP Policies are enabled - Add Impact Statement (Ticket 10942)
Jun 18, 2020	1.2.0	UPDATE - 3.6 (L2) Ensure that external users cannot share files, folders, and sites they do not own - Add Impact Statement (Ticket 10943)
Jun 18, 2020	1.2.0	UPDATE - 3.7 (L2) Ensure external file sharing in Teams is enabled only for approved services - Add Impact Statement (Ticket 10944)
Jun 18, 2020	1.2.0	UPDATE - 4.7 (L2) - Ensure ATP Safelinks are enabled - Impact Statement (Ticket 10945)
Jun 18, 2020	1.2.0	UPDATE - 6.1 (L2) Ensure document sharing is being controlled - Impact Statement (Ticket 10956)
Jun 18, 2020	1.2.0	UPDATE - 7.4 (L1) Ensure that users cannot connect from devices that are jail broken or rooted - Impact Statement (Ticket 10957)
Jun 18, 2020	1.2.0	UPDATE - 4.2 (L1) Ensure Exchange Online Spam Policies are set correctly - Impact Statement (Ticket 10946)
Jun 18, 2020	1.2.0	UPDATE - 4.3 (L1) Ensure mail transport rules do not forward - Impact Statement (Ticket 10947)
Jun 18, 2020	1.2.0	UPDATE - 4.6 (L2) Ensure the Client Rules Forwarding Block - Impact Statement (Ticket 10950)
Jun 18, 2020	1.2.0	UPDATE - 4.14 (L1) Ensure notifications for internal users sending malware is Enabled - Impact Statement (Ticket 10951)

Date	Version	Changes for this version
Jun 19, 2020	1.2.0	UPDATE - 4.5 (L1) Ensure mail transport rules do not whitelist specific domains - Impact Statement (Ticket 10949)
Jun 19, 2020	1.2.0	UPDATE - 4.10 (L1) Ensure that an anti-phishing policy has been created - Impact Statement (Ticket 10955)
Jun 19, 2020	1.2.0	UPDATE - 4.11 (L1) Ensure that DKIM is enabled - Impact Statement (Ticket 10954)
Jun 19, 2020	1.2.0	UPDATE - 4.13 (L1) Ensure DMARC Records for all Exchange Online domains are published - Impact Statement (Ticket 10952)
Jun 19, 2020	1.2.0	UPDATE - 1.1.2 Check for non-MFA users limited to 500 users - Change to manual (Ticket 9394)

ARCHIV